

1. İşletim Sistemi ve Şifreleme: "Anahtarlar Kimde?"

SSH Private Key (Gizli Anahtar)

Normal parola yerine ssh key kullanmamızın nedeni ssh key'de kriptografi kullanılmasıdır. Daha spesifik olacaksak asimetrik kriptografi vardır yani public key ile private key vardır. Temel mantık şu, sunucu bir veri üretir. İstemci bunu private key ile imzalar. Sunucu public key ile imzayı doğrular.

Parola temelli sistemlerin daha güvensiz olmasının nedenleri

Kimlik doğrulama sadece bir sırda dayanır. Sunucu parola hash'ini tutabilir.

Brute force, credential spraying gibi saldırılara açıktır.

İnsanın da bir faktör olması bir dezavantajdır.

Hex Dump

Bir bilgisayar dosyaları binary formatında saklar yani ikili sayı sistemi (0 ve 1). Biz bu veriyi direkt olarak okuyamayız. Hex dump ise binary (ikili) veriyi on altılık sayı sistemine çevirir (hexadecimal). Hexadecimal olması ASCII kod tablosunda karşılığını görebilmemizi sağlar. Hex dump önemi şunlardır; Binary dosya analizi, Exploit geliştirme, Reverse engineering ve Forensic analiz gibi alanlar.

2. Web Mimarisi: "Sunucu Tarafı (Server-Side)"

Client-Side vs Server-Side

Bir tarayıcıda kaynağı görüntüle dediğimizde sadece HTML, CSS ve JS görürüz. Bu kodlar istemciye gönderilir ve tarayıcılarda çalışır. PHP ve Python neden görünmüyor? Bunun nedeni PHP, Python kodu sunucuda çalıştığındandır. Bunlar çalıştırıldıktan sonra çıktı üretilir ve tarayıcıya yalnızca üretilmiş HTML çıktısı gönderilir.

Command Injection (Komut Enjeksiyonu)

Command Injection bir sunucunun kullanıcıdan aldığı veriyi yeterince filtrelemeden veya kontrol etmeden işleminden geçirmesi sonucu doğrudan sistem komutları ile etkileşime geçmesi sonucudur. Bir web server arka planda bildiğimiz linux komutlarını çalıştırır.

Örneğin arama kutusuna elma yazdık.

Sunucu bunu çalıştırır: grep elma dosya.txt – buradaki normal bir senaryo

Ama eğer elma; whoami yazarsak.

Server şunu görebilir: grep elma dosya.txt; whoami

Buradaki “;” işareti ilk komut sonrası ikinci komutu çalıştır demektir. Yani elmadan sonra whoami çalıştırılacaktır demek.

3. Ağ Anatomisi: "Avin İzleri"

C2 (Command and Control) Nedir?

C2 bir saldırganın bulaştırdığı zararlı yazılımı uzaktan kontrol etmesini sağlayan alt yapıdır. Zararlı yazılımın bulaştığı sistemde tek başına bir işlev yapamaz. Genellikle talimat almak, veri göndermek için saldırganın kontrol ettiği bir C2 server'ına bağlanır.

Bir zararlı yazılımın C2'ye bağlanmasının nedenleri:

Komut almak yani, dosya indirmek, modül çalıştırmak, keylogger başlatmak ve yatay hareket yapmak gibi eylemler olur.

PCAP Analizi

Bir SOC analistinin sadece antivirüs loglarına güvenmemesinin nedenleri nedir?

Antivirüs sadece bildiği imzaları yakalar, gelişmiş yazılımları (zero day gibi) görmeyebilir, log'ları manipüle edilebilir. Bu yüzden PCAP den bahsedeceğiz.

PCAP dosyası/paketi ağdaki tüm paketlerin ham kaydı sayılır yani: kim, kime bağlandı, hangi ip adresi, hangi port, protokol ne, ne zaman, dns sorguları, tls trafiği. Bunların hepsini görebilir. Bunlar SOC analistinin aradığı ve ihtiyacı olduğu bilgilerdir.

Cephe 1: İşletim Sistemleri Ustası (Linux / Bash)

OverTheWire: Bandit

```
(kali㉿kali)-[~]
└─$ ssh bandit10@bandit.labs.overthewire.org -p 2220
```



File System

This is an OverTheWire game server.
More information on <http://www.overthewire.org/wargames>

backend: gibbon-1
bandit10@bandit.labs.overthewire.org's password:

10. bölüme giriş yapıyoruz.

```
--[ More information ]--

For more information regarding individual wargames, visit
http://www.overthewire.org/wargames/

For support, questions or comments, contact us on discord or IRC.

Enjoy your stay!

bandit10@bandit:~$ ls
data.txt
bandit10@bandit:~$ cat data.txt
VGhLIHBhc3N3b3JkIGlzIGR0UjE3M2ZaS2IwUlJzREZTR3NnMlJXbnBOVmozcVJyCg==
bandit10@bandit:~$
```

Giriş yaptıktan sonra list yazıp txt dosyasını açıyoruz. Base64 ile encode edildiğini yapısından anlayabiliyoruz(=).

```
(kali㉿kali)-[~]  
$ echo "VGhlIHBhc3N3b3JkIGlzIGR0UjE3M2ZaS2IwUlJzREZTR3NnMlJXbnBOVmozcVJyCg==" | base64 -d  
The password is dtR173fZKb0RRsDFSGsg2RWnpNVj3qRr  
  
(kali㉿kali)-[~]  
$
```

Base64 olduğu için hemen decode ediyoruz.

echo = ekrana yazdır

| = komut çıktısını başka komuta girdi olarak gönder

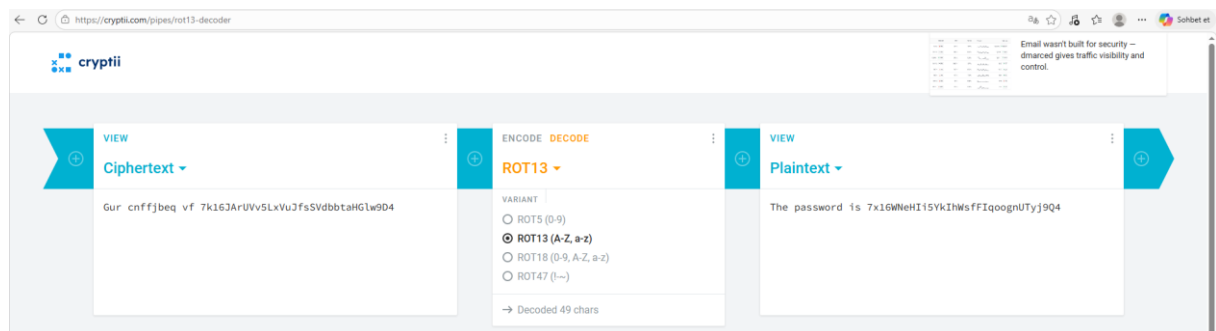
base64 = toolun kendisi

-d = decode et

Decode sonrası: The password is “parola” çıktısını alıyoruz.

```
For more information regarding individual wargames, visit  
http://www.overthewire.org/wargames/  
  
For support, questions or comments, contact us on discord or IRC.  
  
Enjoy your stay!  
  
bandit11@bandit:~$ ls  
data.txt  
bandit11@bandit:~$ cat data.txt  
Gur cnffjbeq vf 7k16JArUVv5LxVuJfsSVdbbtaHGlw9D4  
bandit11@bandit:~$
```

Bir önceki bölümün birebir aynısı. Bu sefer ROT13 ile şifrelenmiş bir veri var.



İnternet üzerinden decode ettiğimiz zaman şifreyi elde ediyoruz.

```
bandit11@bandit:~$ echo "Gur cnffjbeq vf 7k16JArUVv5LxVuJfsSVdbbtaHGlw9D4" | tr 'A-Za-z' 'N-ZA-Mn-za-m'  
The password is 7x16WNeHI15YkIhWsfFIqoognUTyj9Q4  
bandit11@bandit:~$
```

Ayrı olarak terminal ile decode edebiliriz.

```
bandit12@bandit:~$ ls
data.txt
bandit12@bandit:~$ cat data.txt
00000000: 1f8b 0808 2e17 ee68 0203 6461 7461 322e .....h..data2.
00000010: 6269 6e00 0134 02cb fd42 5a68 3931 4159 bin..4...BZh91AY
00000020: 2653 59b6 7680 8b00 001a ffff fadd cfd6 8SY.v.....
00000030: f2e7 f6bb b87f 57ee fff3 b7d7 8bfd fafe .....W.....
00000040: bffe fdfd d9ef 3dff bfff bfff b001 3aa1 .....=.....:
00000050: a40d 007a 9901 a000 1a01 a000 1934 7a80 ...z.....4z.
00000060: 6993 469a 6800 0068 1a00 0340 680d 0d00 i.F.h..h...@h...
00000070: 01a6 8794 188d 0c27 a8d3 4608 8006 4d01 ..... ' ..F...M.
00000080: 8800 3268 c8d0 3434 0006 9a19 0f50 3400 ..2h..44.....P4.
00000090: 1840 6403 2064 0034 1934 c468 c862 6868 .@d. d.4.4.h.bhh
000000a0: c801 a000 68f5 0e9e a346 8343 4346 8698 ....h....F.CCF..
000000b0: 40d0 0686 864c 9b48 0000 0003 40d3 4d34 @....L.H....@.M4
000000c0: 3231 3261 0003 46d4 01ea 0000 1a00 d000 212a..F.....
000000d0: 0d00 0020 c002 3067 df82 0e7a a6f5 b39a ... ..0g...z....
000000e0: 6472 0263 7c59 8eaf c404 a738 aece fe35 dr.c|Y.....8...5
000000f0: 1921 a104 6114 268f 7f45 0411 a3de efc3 .!..a.&..E.....
00000100: 7905 de6d 2229 95e1 a0e0 0d61 13bd 457e y..m").....a..E~
00000110: 5ea0 e955 1a0c c20c dbf5 853e 0177 370e ^..U.....>.w7.
00000120: 073a 1fb3 2b32 57b7 0c16 1ae4 c817 ac62 .:..+2W.....b
00000130: 94ca ed32 1d62 6acb 0e94 e932 2b6f 9702 ...2.bj....2+o..
00000140: 4480 2c49 9192 eab8 fc13 dd5d 4ebb 4495 D.,I.....]N.D.
00000150: a8c5 81d9 e2b8 e68d 291e e9e2 11ee cc35 ..... ).....5
00000160: 6460 63e7 fc6c 1575 7984 da54 8626 21d6 d`c..l.uy..T.&!.
00000170: 8888 2469 cb2e 4229 6f7a 9658 174a 2edd ..$i..B)oz.X.J..
00000180: 2381 252f 2b81 5693 5f96 432d 4f17 25e8 #.%/+..V.._..C-0.%.
00000190: 9129 100e 4ef1 83ca 11de 610d 7bb0 33f0 .) ..N.....a.{.3.
000001a0: a3d7 a77c dab0 cfdb 4793 5bda b7a1 2573 ...|....G.[...%s
000001b0: 0ce4 d2f2 a221 1c83 5053 dd24 bacd f161 .....! ..PS.$...a
000001c0: 22d9 f42b 903d 68c4 479e c021 f658 7a32 " ..+.=h.G..!.Xz2
000001d0: 67c6 975e 8b25 7c28 2ad6 119e d5e6 dbcf g..^.%|(*.....
000001e0: 2469 7a74 fa67 3ea2 235e 1500 6deb f009 $izt.g>.#^..m...
000001f0: 3ad0 ef6e 444d 15e9 fdc2 67bc 01f3 1764 : ..nDM....g....d
00000200: 980e b3c6 045f ef4b ffd1 e529 4130 2141 ....._..K... )A0!A
00000210: ca03 5c28 dce0 5f73 ecec b637 d1fe 852f ..\ ( .._s ...7 .../
00000220: f9eb 416b b5fd df54 8aa6 0b08 022d 7160 ..Ak...T.....-q`
00000230: 215d f790 ccb0 f047 9240 083c d2a6 c098 !].....G.@.<....
00000240: 04bf f8bb 9229 c284 85b3 b404 5856 1e5b ..... ).....XV.[
00000250: 9034 0200 00 .....4...
bandit12@bandit:~$
```

Karşımızda bir hexdump veri var, kısaca veriyi on altılık sayı sistemi ile gösterme yöntemi gibi düşünebiliriz.

Bandit Level 12 → Level 13

[Donate!](#) [File](#)

Level Goal

The password for the next level is stored in the file **data.txt**, which is a hexdump of a file that has been repeatedly compressed. For this level it may be useful to create a directory under /tmp in which you can work. Use **mkdir** with a hard to guess directory name. Or better, use the command "mktemp -d". Then copy the datafile using **cp**, and rename it using **mv** (read the manpages!)

Commands you may need to solve this level

grep, sort, uniq, strings, base64, tr, tar, gzip, bzip2, xxd, mkdir, cp, mv, file

Helpful Reading Material

Hex dump on Wikipedia

Bize bölümün kendisi zaten devamlı olarak sıkıştırıldığını söylemiş bize kalan bunu çözmek.

```
bandit12@bandit:~$ cd ..
bandit12@bandit:/home$ ls
bandit0  bandit22  bandit31-git  behemoth6  drifter7  krypton7  manpage6  narnia3  utumno7  vortex20
bandit1  bandit23  bandit32  behemoth7  drifter8  leviathan0  manpage7  narnia4  utumno8  vortex21
bandit10  bandit24  bandit33  behemoth8  drifter9  leviathan1  maze0  narnia5  vortex0  vortex22
bandit11  bandit25  bandit4  drifter0  formulaone0  leviathan2  maze1  narnia6  vortex1  vortex23
bandit12  bandit26  bandit5  drifter1  formulaone1  leviathan3  maze2  narnia7  vortex10  vortex24
bandit13  bandit27  bandit6  drifter10  formulaone2  leviathan4  maze3  narnia8  vortex11  vortex25
bandit14  bandit27-git  bandit7  drifter12  formulaone3  leviathan5  maze4  narnia9  vortex12  vortex3
bandit15  bandit28  bandit8  drifter13  formulaone5  leviathan6  maze5  ubuntu  vortex13  vortex4
bandit16  bandit28-git  bandit9  drifter14  formulaone6  leviathan7  maze6  utumno0  vortex14  vortex5
bandit17  bandit29  behemoth0  drifter15  krypton1  manpage0  maze7  utumno1  vortex15  vortex6
bandit18  bandit29-git  behemoth1  drifter2  krypton2  manpage1  maze8  utumno2  vortex16  vortex7
bandit19  bandit3  behemoth2  drifter3  krypton3  manpage2  maze9  utumno3  vortex17  vortex8
bandit2  bandit30  behemoth3  drifter4  krypton4  manpage3  narnia0  utumno4  vortex18  vortex9
bandit20  bandit30-git  behemoth4  drifter5  krypton5  manpage4  narnia1  utumno5  vortex19
bandit21  bandit31  behemoth5  drifter6  krypton6  manpage5  narnia2  utumno6  vortex2
bandit12@bandit:/home$ cd ..
bandit12@bandit:/home$ ls
behemoth  dev  home  lib64  manpage  narnia  run  srv  utumno
bin  drifter  krypton  lib.usr-is-merged  maze  opt  sbin  sys  var
bin.usr-is-merged  etc  lib  libx32  media  proc  sbin.usr-is-merged  tmp  vortex
boot  formulaone  lib32  lost+found  mnt  root  snap  usr
bandit12@bandit:/home$ cd tmp
bandit12@bandit:/tmp$ ls
ls: cannot open directory '.': Permission denied
bandit12@bandit:/tmp$ mkdir bandit12cozum
bandit12@bandit:/tmp$ ls
ls: cannot open directory '.': Permission denied
bandit12@bandit:/tmp$ cd ..
bandit12@bandit:/home$ cd bandit12
bandit12@bandit:/home$ cd bandit12
bandit12@bandit:/home$ mkdir /tmp/bandit12cozum
mkdir: cannot create directory '/tmp/bandit12cozum': File exists
bandit12@bandit:/home$ cp data.txt /tmp/bandit12cozum
bandit12@bandit:/home$ cd /tmp/bandit12cozum
bandit12@bandit:/tmp/bandit12cozum$ ls
data.txt
bandit12@bandit:/tmp/bandit12cozum$
```

Veriyi tmp klasörü içerisinde boş bir dizine aldım. Bölümün açıklaması bize bunu öneriyor rahatça çalışmak için.

```
bandit12@bandit:/tmp/bandit12cozum$ xxd -r data.txt
00000000: 44 45 46 47 48 49 50 51 52 53 54 55 56 57 58 59  DE
00000010: 60 61 62 63 64 65 66 67 68 69 70 71 72 73 74 75  DE
00000020: 76 77 78 79 80 81 82 83 84 85 86 87 88 89 90 91  DE
00000030: 92 93 94 95 96 97 98 99 100 101 102 103 104 105 106 107  DE
00000040: 108 109 110 111 112 113 114 115 116 117 118 119 120 121 122 123  DE
00000050: 124 125 126 127 128 129 130 131 132 133 134 135 136 137 138 139  DE
00000060: 140 141 142 143 144 145 146 147 148 149 150 151 152 153 154 155  DE
00000070: 156 157 158 159 160 161 162 163 164 165 166 167 168 169 170 171  DE
00000080: 172 173 174 175 176 177 178 179 180 181 182 183 184 185 186 187  DE
00000090: 188 189 190 191 192 193 194 195 196 197 198 199 200 201 202 203  DE
000000a0: 204 205 206 207 208 209 210 211 212 213 214 215 216 217 218 219  DE
000000b0: 220 221 222 223 224 225 226 227 228 229 230 231 232 233 234 235  DE
000000c0: 236 237 238 239 240 241 242 243 244 245 246 247 248 249 250 251  DE
000000d0: 252 253 254 255 256 257 258 259 260 261 262 263 264 265 266 267  DE
000000e0: 268 269 270 271 272 273 274 275 276 277 278 279 280 281 282 283  DE
000000f0: 284 285 286 287 288 289 290 291 292 293 294 295 296 297 298 299  DE
00000100: 300 301 302 303 304 305 306 307 308 309 310 311 312 313 314 315  DE
00000110: 316 317 318 319 320 321 322 323 324 325 326 327 328 329 330 331  DE
00000120: 332 333 334 335 336 337 338 339 340 341 342 343 344 345 346 347  DE
00000130: 348 349 350 351 352 353 354 355 356 357 358 359 360 361 362 363  DE
00000140: 364 365 366 367 368 369 370 371 372 373 374 375 376 377 378 379  DE
00000150: 380 381 382 383 384 385 386 387 388 389 390 391 392 393 394 395  DE
00000160: 396 397 398 399 400 401 402 403 404 405 406 407 408 409 410 411  DE
00000170: 412 413 414 415 416 417 418 419 420 421 422 423 424 425 426 427  DE
00000180: 428 429 430 431 432 433 434 435 436 437 438 439 440 441 442 443  DE
00000190: 444 445 446 447 448 449 450 451 452 453 454 455 456 457 458 459  DE
000001a0: 460 461 462 463 464 465 466 467 468 469 470 471 472 473 474 475  DE
000001b0: 476 477 478 479 480 481 482 483 484 485 486 487 488 489 490 491  DE
000001c0: 492 493 494 495 496 497 498 499 500 501 502 503 504 505 506 507  DE
000001d0: 508 509 510 511 512 513 514 515 516 517 518 519 520 521 522 523  DE
000001e0: 524 525 526 527 528 529 530 531 532 533 534 535 536 537 538 539  DE
000001f0: 540 541 542 543 544 545 546 547 548 549 550 551 552 553 554 555  DE
00000200: 556 557 558 559 560 561 562 563 564 565 566 567 568 569 570 571  DE
00000210: 572 573 574 575 576 577 578 579 580 581 582 583 584 585 586 587  DE
00000220: 588 589 590 591 592 593 594 595 596 597 598 599 600 601 602 603  DE
00000230: 604 605 606 607 608 609 610 611 612 613 614 615 616 617 618 619  DE
00000240: 620 621 622 623 624 625 626 627 628 629 630 631 632 633 634 635  DE
00000250: 636 637 638 639 640 641 642 643 644 645 646 647 648 649 650 651  DE
00000260: 652 653 654 655 656 657 658 659 660 661 662 663 664 665 666 667  DE
00000270: 668 669 670 671 672 673 674 675 676 677 678 679 680 681 682 683  DE
00000280: 684 685 686 687 688 689 690 691 692 693 694 695 696 697 698 699  DE
00000290: 700 701 702 703 704 705 706 707 708 709 710 711 712 713 714 715  DE
000002a0: 716 717 718 719 720 721 722 723 724 725 726 727 728 729 730 731  DE
000002b0: 732 733 734 735 736 737 738 739 740 741 742 743 744 745 746 747  DE
000002c0: 748 749 750 751 752 753 754 755 756 757 758 759 760 761 762 763  DE
000002d0: 764 765 766 767 768 769 770 771 772 773 774 775 776 777 778 779  DE
000002e0: 780 781 782 783 784 785 786 787 788 789 790 791 792 793 794 795  DE
000002f0: 796 797 798 799 800 801 802 803 804 805 806 807 808 809 810 811  DE
00000300: 812 813 814 815 816 817 818 819 820 821 822 823 824 825 826 827  DE
00000310: 828 829 830 831 832 833 834 835 836 837 838 839 840 841 842 843  DE
00000320: 844 845 846 847 848 849 850 851 852 853 854 855 856 857 858 859  DE
00000330: 860 861 862 863 864 865 866 867 868 869 870 871 872 873 874 875  DE
00000340: 876 877 878 879 880 881 882 883 884 885 886 887 888 889 890 891  DE
00000350: 892 893 894 895 896 897 898 899 900 901 902 903 904 905 906 907  DE
00000360: 908 909 910 911 912 913 914 915 916 917 918 919 920 921 922 923  DE
00000370: 924 925 926 927 928 929 930 931 932 933 934 935 936 937 938 939  DE
00000380: 940 941 942 943 944 945 946 947 948 949 950 951 952 953 954 955  DE
00000390: 956 957 958 959 960 961 962 963 964 965 966 967 968 969 970 971  DE
000003a0: 972 973 974 975 976 977 978 979 980 981 982 983 984 985 986 987  DE
000003b0: 988 989 990 991 992 993 994 995 996 997 998 999 1000 1001 1002 1003  DE
000003c0: 1004 1005 1006 1007 1008 1009 1010 1011 1012 1013 1014 1015 1016 1017 1018 1019  DE
000003d0: 1020 1021 1022 1023 1024 1025 1026 1027 1028 1029 1030 1031 1032 1033 1034 1035  DE
000003e0: 1036 1037 1038 1039 1040 1041 1042 1043 1044 1045 1046 1047 1048 1049 1050 1051  DE
000003f0: 1052 1053 1054 1055 1056 1057 1058 1059 1060 1061 1062 1063 1064 1065 1066 1067  DE
00000400: 1068 1069 1070 1071 1072 1073 1074 1075 1076 1077 1078 1079 1080 1081 1082 1083  DE
00000410: 1084 1085 1086 1087 1088 1089 1090 1091 1092 1093 1094 1095 1096 1097 1098 1099  DE
00000420: 1100 1101 1102 1103 1104 1105 1106 1107 1108 1109 1110 1111 1112 1113 1114 1115  DE
00000430: 1116 1117 1118 1119 1120 1121 1122 1123 1124 1125 1126 1127 1128 1129 1130 1131  DE
00000440: 1132 1133 1134 1135 1136 1137 1138 1139 1140 1141 1142 1143 1144 1145 1146 1147  DE
00000450: 1148 1149 1150 1151 1152 1153 1154 1155 1156 1157 1158 1159 1160 1161 1162 1163  DE
00000460: 1164 1165 1166 1167 1168 1169 1170 1171 1172 1173 1174 1175 1176 1177 1178 1179  DE
00000470: 1180 1181 1182 1183 1184 1185 1186 1187 1188 1189 1190 1191 1192 1193 1194 1195  DE
00000480: 1196 1197 1198 1199 1200 1201 1202 1203 1204 1205 1206 1207 1208 1209 1210 1211  DE
00000490: 1212 1213 1214 1215 1216 1217 1218 1219 1220 1221 1222 1223 1224 1225 1226 1227  DE
000004a0: 1228 1229 1230 1231 1232 1233 1234 1235 1236 1237 1238 1239 1240 1241 1242 1243  DE
000004b0: 1244 1245 1246 1247 1248 1249 1250 1251 1252 1253 1254 1255 1256 1257 1258 1259  DE
000004c0: 1260 1261 1262 1263 1264 1265 1266 1267 1268 1269 1270 1271 1272 1273 1274 1275  DE
000004d0: 1276 1277 1278 1279 1280 1281 1282 1283 1284 1285 1286 1287 1288 1289 1290 1291  DE
000004e0: 1292 1293 1294 1295 1296 1297 1298 1299 1300 1301 1302 1303 1304 1305 1306 1307  DE
000004f0: 1308 1309 1310 1311 1312 1313 1314 1315 1316 1317 1318 1319 1320 1321 1322 1323  DE
00000500: 1324 1325 1326 1327 1328 1329 1330 1331 1332 1333 1334 1335 1336 1337 1338 1339  DE
00000510: 1340 1341 1342 1343 1344 1345 1346 1347 1348 1349 1350 1351 1352 1353 1354 1355  DE
00000520: 1356 1357 1358 1359 1360 1361 1362 1363 1364 1365 1366 1367 1368 1369 1370 1371  DE
00000530: 1372 1373 1374 1375 1376 1377 1378 1379 1380 1381 1382 1383 1384 1385 1386 1387  DE
00000540: 1388 1389 1390 1391 1392 1393 1394 1395 1396 1397 1398 1399 1400 1401 1402 1403  DE
00000550: 1404 1405 1406 1407 1408 1409 1410 1411 1412 1413 1414 1415 1416 1417 1418 1419  DE
00000560: 1420 1421 1422 1423 1424 1425 1426 1427 1428 1429 1430 1431 1432 1433 1434 1435  DE
00000570: 1436 1437 1438 1439 1440 1441 1442 1443 1444 1445 1446 1447 1448 1449 1450 1451  DE
00000580: 1452 1453 1454 1455 1456 1457 1458 1459 1460 1461 1462 1463 1464 1465 1466 1467  DE
00000590: 1468 1469 1470 1471 1472 1473 1474 1475 1476 1477 1478 1479 1480 1481 1482 1483  DE
000005a0: 1484 1485 1486 1487 1488 1489 1490 1491 1492 1493 1494 1495 1496 1497 1498 1499  DE
000005b0: 1500 1501 1502 1503 1504 1505 1506 1507 1508 1509 1510 1511 1512 1513 1514 1515  DE
000005c0: 1516 1517 1518 1519 1520 1521 1522 1523 1524 1525 1526 1527 1528 1529 1530 1531  DE
000005d0: 1532 1533 1534 1535 1536 1537 1538 1539 1540 1541 1542 1543 1544 1545 1546 1547  DE
000005e0: 1548 1549 1550 1551 1552 1553 1554 1555 1556 1557 1558 1559 1560 1561 1562 1563  DE
000005f0: 1564 1565 1566 1567 1568 1569 1570 1571 1572 1573 1574 1575 1576 1577 1578 1579  DE
00000600: 1580 1581 1582 1583 1584 1585 1586 1587 1588 1589 1590 1591 1592 1593 1594 1595  DE
00000610: 1596 1597 1598 1599 1600 1601 1602 1603 1604 1605 1606 1607 1608 1609 1610 1611  DE
00000620: 1612 1613 1614 1615 1616 1617 1618 1619 1620 1621 1622 1623 1624 1625 1626 1627  DE
00000630: 1628 1629 1630 1631 1632 1633 1634 1635 1636 1637 1638 1639 1640 1641 1642 1643  DE
00000640: 1644 1645 1646 1647 1648 1649 1650 1651 1652 1653 1654 1655 1656 1657 1658 1659  DE
00000650: 1660 1661 1662 1663 1664 1665 1666 1667 1668 1669 1670 1671 1672 1673 1674 1675  DE
00000660: 1676 1677 1678 1679 1680 1681 1682 1683 1684 1685 1686 1687 1688 1689 1690 1691  DE
00000670: 1692 1693 1694 1695 1696 1697 1698 1699 1700 1701 1702 1703 1704 1705 1706 1707  DE
00000680: 1708 1709 1710 1711 1712 1713 1714 1715 1716 1717 1718 1719 1720 1721 1722 1723  DE
00000690: 1724 1725 1726 1727 1728 1729 1730 1731 1732 1733 1734 1735 1736 1737 1738 1739  DE
000006a0: 1740 1741 1742 1743 1744 1745 1746 1747 1748 1749 1750 1751 1752 1753 1754 1755  DE
000006b0: 1756 1757 1758 1759 1760 1761 1762 1763 1764 1765 1766 1767 1768 1769 1770 1771  DE
000006c0: 1772 1773 1774 1775 1776 1777 1778 1779 1780 1781 1782 1783 1784 1785 1786 1787  DE
000006d0: 1788 1789 1790 1791 1792 1793 1794 1795 1796 1797 1798 1799 1800 1801 1802 1803  DE
000006e0: 1804 1805 1806 1807 1808 1809 1810 1811 1812 1813 1814 1815 1816 1817 1818 1819  DE
000006f0: 1820 1821 1822 1823 1824 1825 1826 1827 1828 1829 1830 1831 1832 1833 1834 1835  DE
00000700: 1836 1837 1838 1839 1840 1841 1842 1843 1844 1845 1846 1847 1848 1849 1850 1851  DE
00000710: 1852 1853 1854 1855 1856 1857 1858 1859 1860 1861 1862 1863 1864 1865 1866 1867  DE
00000720: 1868 1869 1870 1871 1872 1873 1874 1875 1876 1877 1878 1879 1880 1881 1882 1883  DE
00000730: 1884 1885 1886 1887 1888 1889 1890 1891 1892 1893 1894 1895 1896 1897 1898 1899  DE
00000740: 1900 1901 1902 1903 1904 1905 1906 1907 1908 1909 1910 1911 1912 1913 1914 1915  DE
00000750: 1916 1917 1918 1919 1920 1921 1922 1923 1924 1925 1926 1927 1928 1929 1930 1931  DE
00000760: 1932 1933 1934 1935 1936 1937 1938 1939 1940 1941 1942 1943 1944 1945 1946 1947  DE
00000770: 1948 1949 1950 1951 1952 1953 1954 1955 1956 1957 1958 1959 1960 1961 1962 1963  DE
00000780: 1964 1965 1966 1967 1968 1969 1970 1971 1972 1973 1974 1975 1976 1977 1978 1979  DE
00000790: 1980 1981 1982 1983 1984 1985 1986 1987 1988 1989 1990 1991 1992 1993 1994 1995  DE
000007a0: 1996 1997 1998 1999 2000 2001 2002 2003 2004 2005 2006 2007 2008 2009 2010 2011  DE
000007b0: 2012 2013 2014 2015 2016 2017 2018 2019 2020 2021 2022 2023 2024 2025 2026 2027  DE
000007c0: 2028 2029 2030 2031 2032 2033 2034 2035 2036 2037 2038 2039 2040 2041 2042 2043  DE
000007d0: 2044 2045 2046 2047 2048 2049 2050 2051 2052 2053 2054 2055 2056 2057 2058 2059  DE
000007e0: 2060 2061 2062 2063 2064 2065 2066 2067 2068 2069 2070 2071 2072 2073 2074 2075  DE
000007f0: 2076 2077 2078 2079 2080 2081 2082 2083 2084 2085 2086 2087 2088 2089 2090 2091  DE
00000800: 2092 2093 2094 2095 2096 2097 2098 2099 2100 2101 2102 2103 2104 2105 2106 2107  DE
00000810: 2108 2109 2110 2111 2112 2113 2114 2115 2116 2117 2118 2119 2120 2121 2122 2123  DE
00000820: 2124 2125 2126 2127 2128 2129 2130 2131 2132 2133 2134 2135 2136 2137 2138 2139  DE
00000830: 2140 2141 2142 2143 2144 2145 2146 2147 2148 2149 2150 2151 2152 2153 2154 2155  DE
00000840: 2156 2157 21
```

File cikti = dosyanın ne tür bir dosta olduğunu söyler

mv cikti cikti.gz = bir dosyayı taşımaya veya yeniden adlandırmaya yarar. Bu senaryodaki kullanım amacı uzantıyı değiştirmektir.

Önce 16lık veriyi tersine çevirdik. Yani ikili sayı sistemine. Sonra bu dosyanın ne biçimde olduğunu öğrendik. Gzip sıkıştırılmış dosya olduğunu gördük ve ardından .gz formatına çevirdik.

```
bandit12@bandit:/tmp/bandit12cozum$ gzip -d cikti.gz
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti data.txt
bandit12@bandit:/tmp/bandit12cozum$ file cikti
cikti: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/bandit12cozum$ mv cikti cikti.bz2
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.bz2 data.txt
```

gzip -d = gzip dosyasını decompress eder yani sıkıştırılmış dosyayı açar.

Tekrardan file komutu ile verinin formatına bakıyoruz ve bize bzip2 sıkıştırılmış veri olduğunu söylüyor. Önceden yaptığımız uzantı değiştirmeyi tekrar yapıyoruz bu sefer bzip olarak (mv cikti cikti.bz2).

```
bandit12@bandit:/tmp/bandit12cozum$ bzip2 -d data.bz2
bzip2: Can't open input file data.bz2: No such file or directory.
bandit12@bandit:/tmp/bandit12cozum$ bzip2 -d cikti.bz2
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti data.txt
bandit12@bandit:/tmp/bandit12cozum$ file cikti
cikti: gzip compressed data, was "data4.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, original size modulo 2^32 20480
bandit12@bandit:/tmp/bandit12cozum$ mv cikti cikti.gz
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.gz data.txt
bandit12@bandit:/tmp/bandit12cozum$ gzip -d cikti.gz
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti data.txt
bandit12@bandit:/tmp/bandit12cozum$ cat cikti
data5.bin000006440000000000000000000000002400015073413456011250 0ustar rootrootdata6.bin000006440000000000000000000000000334
Qi*F+L+A+z5*M+CFCqb2b+Lu+6l+*****q@A+]*8[9*NB+E+V+k+ vQ+*****Edq2H+!*****<m+*2+3+'*T
7*L+5GzE+]*B+C+f+Hbandit12@bandit:/tmp/bandit12cozum$ file cikti
cikti: POSIX tar archive (GNU)
bandit12@bandit:/tmp/bandit12cozum$ mv cikti cikti.tar
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data.txt
bandit12@bandit:/tmp/bandit12cozum$ tar xf cikti.tar
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.bin data.txt
bandit12@bandit:/tmp/bandit12cozum$ file data5.bin
data5.bin: POSIX tar archive (GNU)
bandit12@bandit:/tmp/bandit12cozum$ mv data5.bin data5.tar
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data.txt
bandit12@bandit:/tmp/bandit12cozum$ tar xf data5.tar
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6.bin data.txt
bandit12@bandit:/tmp/bandit12cozum$ file data6.bin
data6.bin: bzip2 compressed data, block size = 900k
bandit12@bandit:/tmp/bandit12cozum$ mv data6.bin data6.bz2
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6.bz2 data.txt
bandit12@bandit:/tmp/bandit12cozum$
```

tar xf = dosyayı çıkarır (data5.bin)

Bu noktadan sonra iş döngüye giriyor diyebiliriz. Artık sadece çıkartacağımız ve uzantısını değiştireceğimiz dosyaların formatını bilmemiz yeterli.

```
bandit12@bandit:/tmp/bandit12cozum$ mv data6.bin data6.bz2
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6.bz2 data.txt
bandit12@bandit:/tmp/bandit12cozum$ bzip2 -d data6.bz2
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6 data.txt
bandit12@bandit:/tmp/bandit12cozum$ file data6
data6: POSIX tar archive (GNU)
bandit12@bandit:/tmp/bandit12cozum$ mv data6 data6.tar
bandit12@bandit:/tmp/bandit12cozum$ tar xf data6.tar
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6.tar data8.bin data.txt
bandit12@bandit:/tmp/bandit12cozum$ file data8.bin
data8.bin: gzip compressed data, was "data9.bin", last modified: Tue Oct 14 09:26:06 2025, max compression, from Unix, original size modulo 2^32 49
bandit12@bandit:/tmp/bandit12cozum$ mv data8.bin data8.gz
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6.tar data8.gz data.txt
bandit12@bandit:/tmp/bandit12cozum$ gzip -d data8.gz
bandit12@bandit:/tmp/bandit12cozum$ ls
cikti.tar data5.tar data6.tar data8 data.txt
bandit12@bandit:/tmp/bandit12cozum$ file data8
data8: ASCII text
bandit12@bandit:/tmp/bandit12cozum$ cat data8
The password is F05dwFsc0cbaIiH0h8J2eUks2vdTDwAn
bandit12@bandit:/tmp/bandit12cozum$
```

En sonra gördüğünüz gibi çıkardığımız gzip dosyasının tipine file komutu ile baktığımızda ASCII text olduğu yazıyor. Dosyayı görüntülediğimizde ise şifreyi görüyoruz. Kısaca file komutu ile dosya tipini anlıyoruz. Doğru uzantıyı veriyoruz. Doğru aracı kullanarak dosyayı çıkartıyoruz. Çıkan dosyayı kontrol edip bu döngüde ilerliyoruz.

Bandit Level 13 → Level 14

[Donate](#) [Help](#)

Level Goal

The password for the next level is stored in `/etc/bandit_pass/bandit14` and can only be read by user `bandit14`. For this level, you don't get the next password, but you get a private SSH key that can be used to log into the next level. Look at the commands that logged you into previous bandit levels, and find out how to use the key for this level.

Commands you may need to solve this level

ssh, scp, umask, chmod, cat, nc, install

Helpful Reading Material

SSH/OpenSSH/Keys

Bir sonraki bölümün şifresinin `/etc/bandit_pass/bandit14` içinde olduğunu söylüyor ve sadece bandit14 kullanıcısının okuyabildiğini söylüyor.

```
bandit13@bandit:/etc$ cd bandit_pass/
bandit13@bandit:/etc/bandit_pass$ ls
bandit0 bandit12 bandit16 bandit2 bandit23 bandit27 bandit30 bandit4 bandit8
bandit1 bandit13 bandit17 bandit20 bandit24 bandit28 bandit31 bandit5 bandit9
bandit10 bandit14 bandit18 bandit21 bandit25 bandit29 bandit32 bandit6
bandit11 bandit15 bandit19 bandit22 bandit26 bandit3 bandit33 bandit7
bandit13@bandit:/etc/bandit_pass$ cd bandit14
-bash: cd: bandit14: Not a directory
bandit13@bandit:/etc/bandit_pass$ cat bandit14
cat: bandit14: Permission denied
bandit13@bandit:/etc/bandit_pass$
```

Yetkimiz yok gördüğünüz üzere. Okuyamıyoruz.


```

bandit13@bandit:/etc/bandit_pass$ cd bandit14
-bash: cd: bandit14: Not a directory
bandit13@bandit:/etc/bandit_pass$ cat bandit14
cat: bandit14: Permission denied
bandit13@bandit:/etc/bandit_pass$ cd ..
bandit13@bandit:/etc$ cat bandit_pass/^C
bandit13@bandit:/etc$ cd bandit_pass/
bandit13@bandit:/etc/bandit_pass$ cat bandit13
F05dwFsc0cbaIiH0h8J2eUks2vdTDwAn
bandit13@bandit:/etc/bandit_pass$ ssh -i sshkey.private bandit.labs.overthewire.org -p 2220 -l bandit14
Warning: Identity file sshkey.private not accessible: No such file or directory.
The authenticity of host '[bandit.labs.overthewire.org]:2220 ([127.0.0.1]:2220)' can't be established.
ED25519 key fingerprint is SHA256:C2ihUBV7ihnV1wUXRb4RrEcLfXC5CXlhmAAM/urerLY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/home/bandit13/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/home/bandit13/.ssh/known_hosts).

      _ _ _ _ _
     /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /   /
    /___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/
   /___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/
  /___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/
 /___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/
/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/___/

This is an OverTheWire game server.
More information on http://www.overthewire.org/wargames

!!! You are trying to log into this SSH server with a password on port 2220 from localhost.
!!! Connecting from localhost is blocked to conserve resources.
!!! Please log out and log in again.

backend: gibbon-1
Received disconnect from 127.0.0.1 port 2220:2: no authentication methods enabled
Disconnected from 127.0.0.1 port 2220
bandit13@bandit:/etc/bandit_pass$ ^Ch -i sshkey.private bandit.labs.overthewire.org -p 2220 -l bandit14
bandit13@bandit:/etc/bandit_pass$ cd
bandit13@bandit:~$ ls
HINT sshkey.private
bandit13@bandit:~$ pwd
/home/bandit13
bandit13@bandit:~$ ssh -i /home/bandit13/sshkey.private bandit.labs.overthewire.org -p 2220 -l bandit14
The authenticity of host '[bandit.labs.overthewire.org]:2220 ([127.0.0.1]:2220)' can't be established.
ED25519 key fingerprint is SHA256:C2ihUBV7ihnV1wUXRb4RrEcLfXC5CXlhmAAM/urerLY.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Could not create directory '/home/bandit13/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/home/bandit13/.ssh/known_hosts).

```

Burada birkaç kere giriş yapmayı denedim ama olmadı.

```

bandit13@bandit:~$ ls -la
total 28
drwxr-xr-x  2 root    root    4096 Mar  3 16:56 .
drwxr-xr-x 150 root    root    4096 Oct 14 09:29 ..
-rw-r--r--  1 root    root     220 Mar 31 2024 .bash_logout
-rw-r--r--  1 root    root    3851 Oct 14 09:19 .bashrc
-rw-r-----  1 bandit14 bandit13 467 Mar  3 16:56 HINT
-rw-r--r--  1 root    root     807 Mar 31 2024 .profile
-rw-r-----  1 bandit14 bandit13 1679 Oct 14 09:26 sshkey.private
bandit13@bandit:~$

```

Sahibinin bandit14 olduğunu ve izinleri gördükten sonra direkt olarak diğer adıma geçtim.

```
(kali@kali)-[~/Downloads]
$ nano bandit14key.private

(kali@kali)-[~/Downloads]
$ ls
1.txt 2.txt 3.txt bandit14key.private eu-central-1-BobMoe-regular.ovpn

(kali@kali)-[~/Downloads]
$ ls -la
total 32
drwxr-xr-x 2 kali kali 4096 Mar  4 06:32 .
drwx----- 21 kali kali 4096 Mar  4 06:01 ..
-rw-rw-r-- 1 kali kali 297 Feb 25 03:42 1.txt
-rw-rw-r-- 1 kali kali 44 Feb 25 03:42 2.txt
-rw-rw-r-- 1 kali kali 77 Feb 25 03:42 3.txt
-rw-rw-r-- 1 kali kali 1679 Mar  4 06:32 bandit14key.private
-rw-rw-r-- 1 kali kali 6099 Feb 24 05:52 eu-central-1-BobMoe-regular.ovpn

(kali@kali)-[~/Downloads]
$ chmod 600 bandit14key.private

(kali@kali)-[~/Downloads]
$ ls -la
total 32
drwxr-xr-x 2 kali kali 4096 Mar  4 06:32 .
drwx----- 21 kali kali 4096 Mar  4 06:01 ..
-rw-rw-r-- 1 kali kali 297 Feb 25 03:42 1.txt
-rw-rw-r-- 1 kali kali 44 Feb 25 03:42 2.txt
-rw-rw-r-- 1 kali kali 77 Feb 25 03:42 3.txt
-rw----- 1 kali kali 1679 Mar  4 06:32 bandit14key.private
-rw-rw-r-- 1 kali kali 6099 Feb 24 05:52 eu-central-1-BobMoe-regular.ovpn

(kali@kali)-[~/Downloads]
$ ssh -i bandit14key.private bandit14@bandit.labs.overthewire.org -p 2220
```

Kendi bandit14 anahtarımı oluşturdum. Bandit13 içindeki ssh anahtarını görüntüleyebiliyorduk hatırlıyorsanız. Anahtarın içeriğini direkt olarak alıp başka bir dosyaya yapıştırdım ve izinlerini de sadece benim görüntüleyebileceğim şekile getirdim (chmod 600)

Neden bunu yaptık. SSH anahtar izinleri çok açık olursa SSH bağlantıya izin vermez. chmod 600 sadece sahibinin okuma/yazma yetkisi olduğunu belirtir.

```
bandit14@bandit:~$ cat /etc/bandit_pass/bandit14
MU4VWeTyJk8ROof1qqmcBPALh7lDCPvS
bandit14@bandit:~$
```

Bu sayede giriş yapıp şifreyi elde edebildim.

Bandit Level 14 → Level 15

Level Goal

The password for the next level can be retrieved by submitting the password of the current level to **port 30000 on localhost**.

Commands you may need to solve this level

ssh, telnet, nc, openssl, s_client, nmap

Helpful Reading Material

[How the Internet works in 5 minutes \(YouTube\)](#) (Not completely accurate, but good enough for beginners)

[IP Addresses](#)

[IP Address on Wikipedia](#)

[Localhost on Wikipedia](#)

[Ports](#)

[Port \(computer networking\) on Wikipedia](#)

Bölümün açıklamasında bir sonraki bölümün şifresini, **şu anda bulunduğun** bölümün şifresinin localhost'daki 30000 numaralı porta gönderip elde edebilirsin diyor.

```
bandit14@bandit:~$ nc localhost 30000
MU4VWeTyJk8R0of1qqmcBPALh7lDCPvSü
Wrong! Please enter the correct current password.

bandit14@bandit:~$ nc localhost 30000
MU4VWeTyJk8R0of1qqmcBPALh7lDCPvS
Correct!
8xCjnmgoKbGLhHFAZlGE5Tmu4M2tKJQo
File System
```

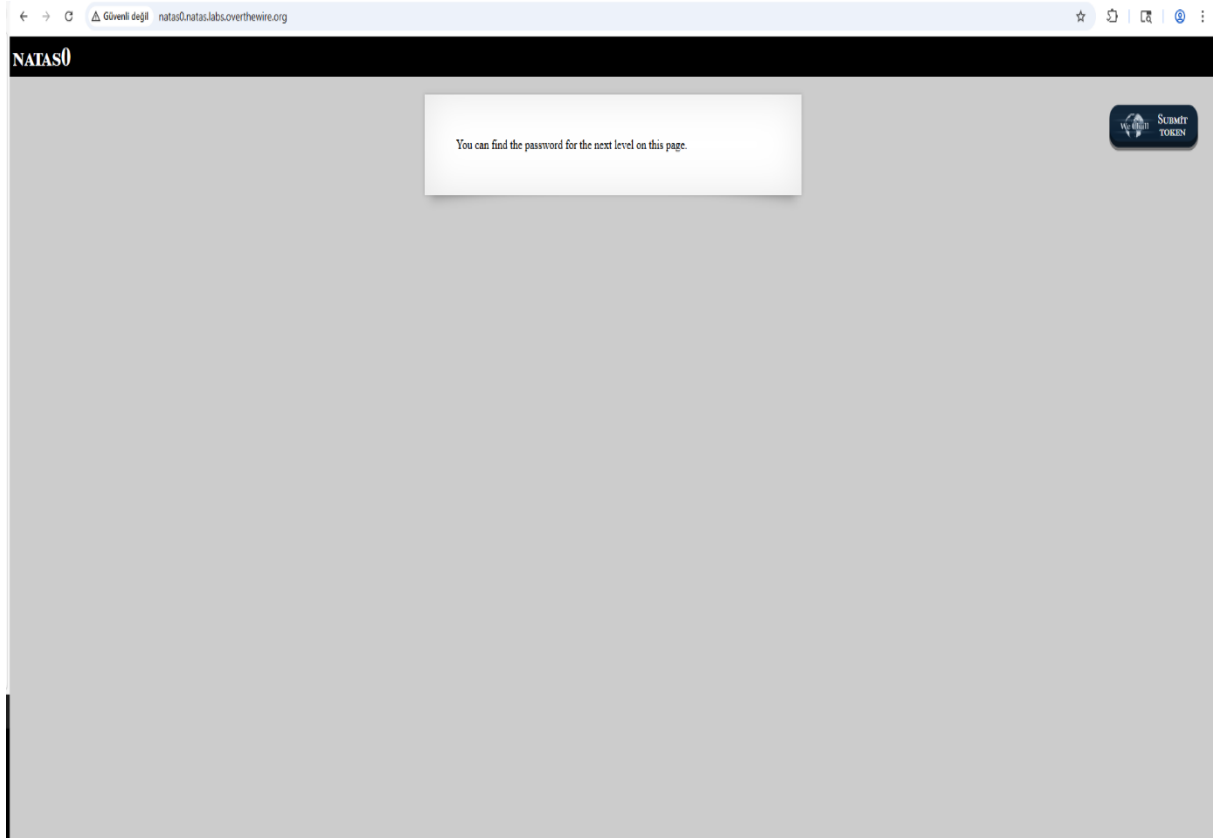
Direkt netcat ile bu işlemi kolayca yapıp parolayı alabiliriz.

Netcat: Netcat TCP/UDP bağlantıları kurmak için kullanılan bir ağ aracıdır. Çok yönlüdür swiss army knife olarak bilinir.

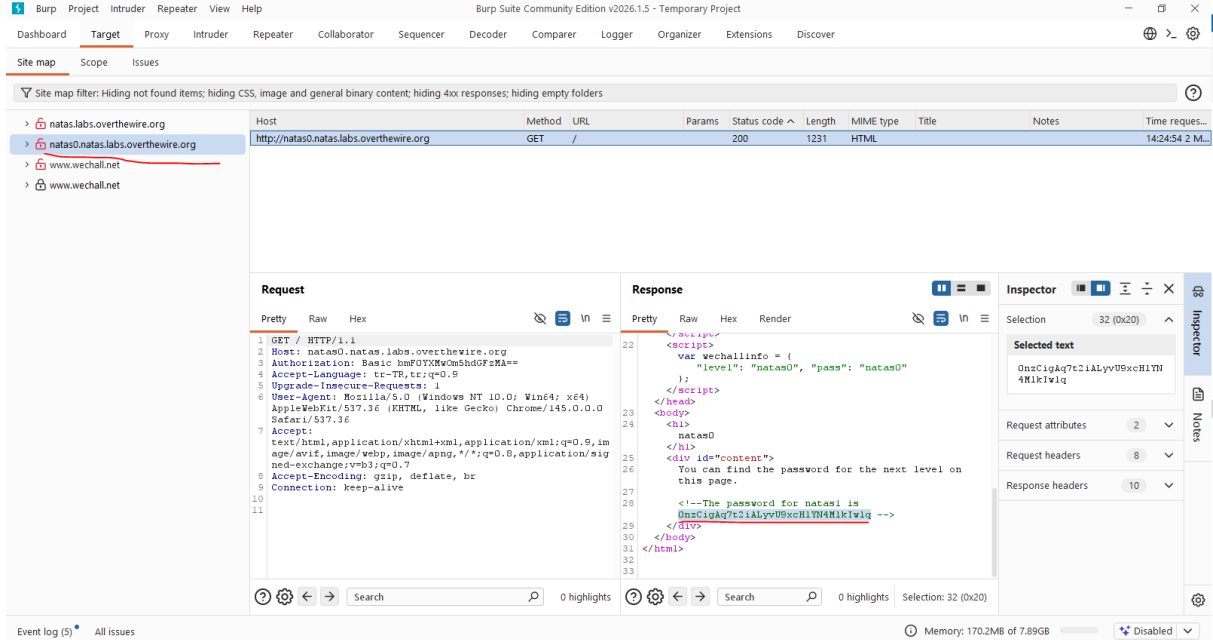
Cephe 2: Web Mantık Avcısı (Server-Side)

OverTheWire: Natas

NATAS0

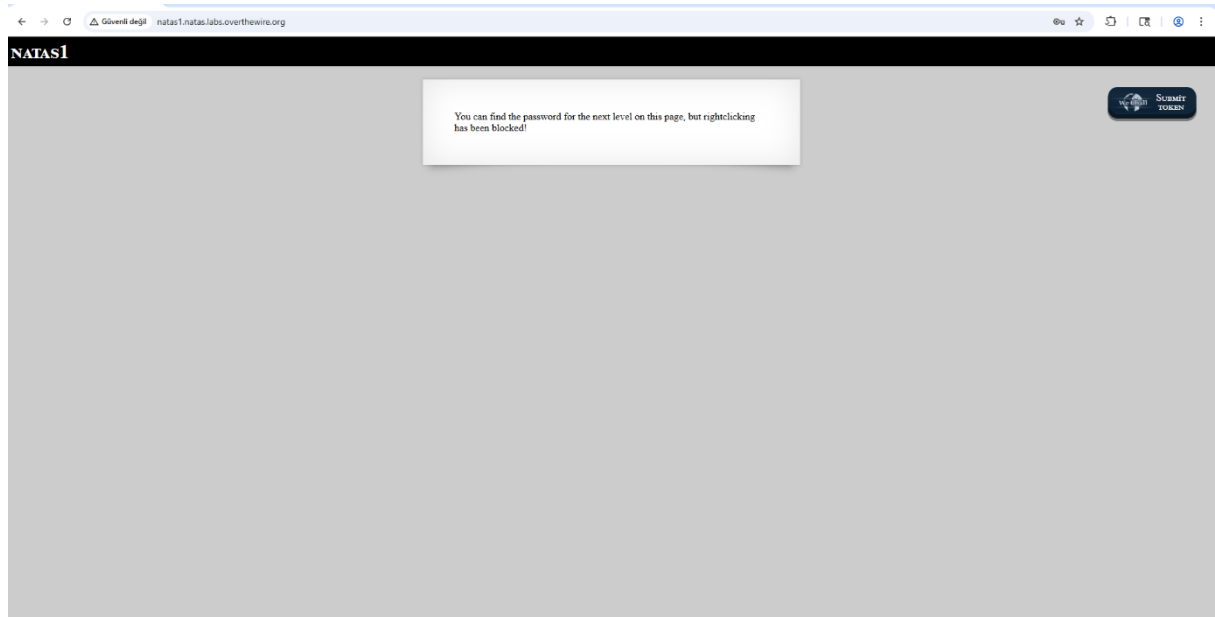


Bize parolanın bu sayfada olduğunu söylüyor.

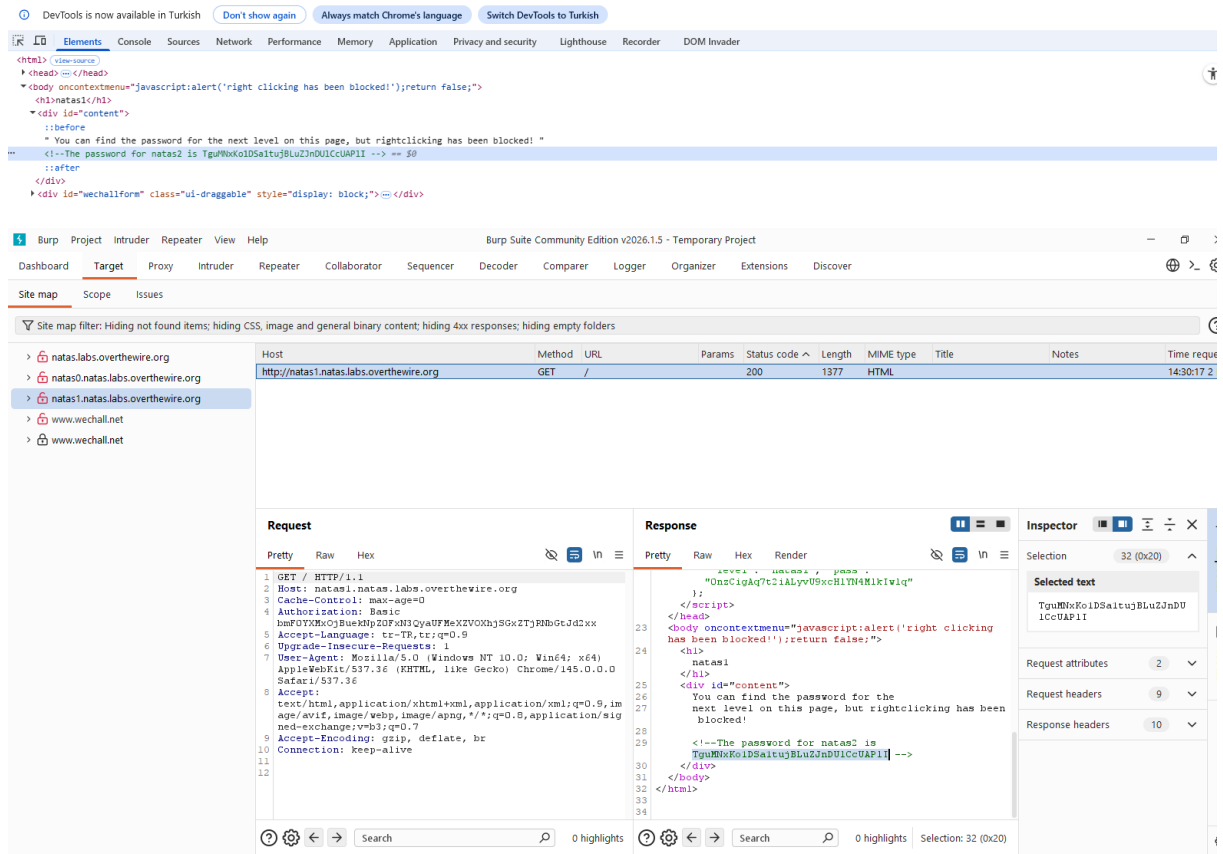


Burada çok basit bir şekilde attığımız isteğin cevabında bir sonraki bölümün şifresini görüyoruz.

NATAS1

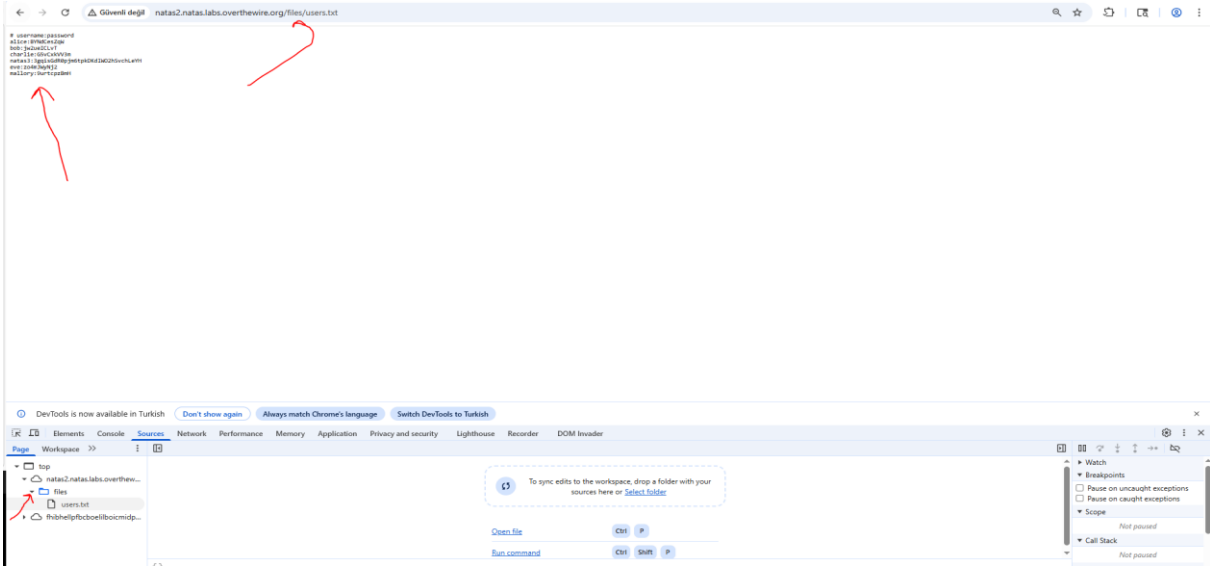
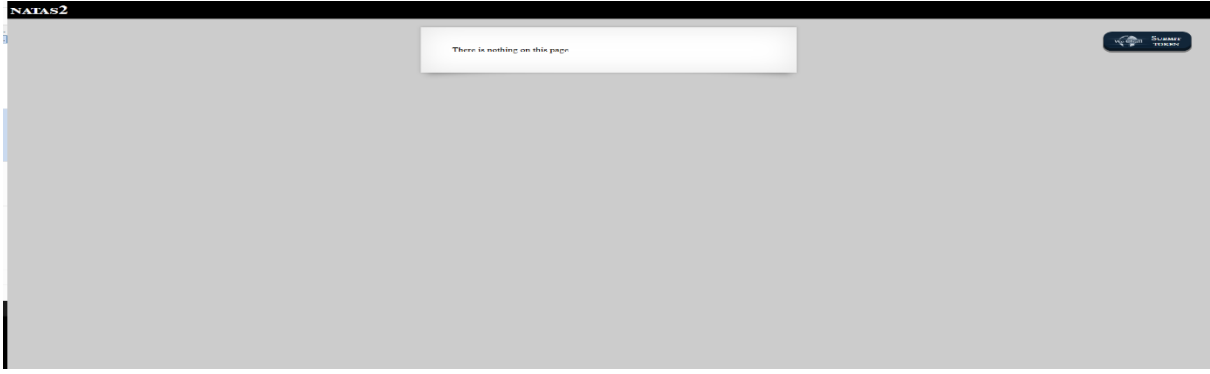


Tekrardan şifrenin bu bölümde olduğunu söylüyor. Ama sağ tıklamayı geçersiz kılmışlar.



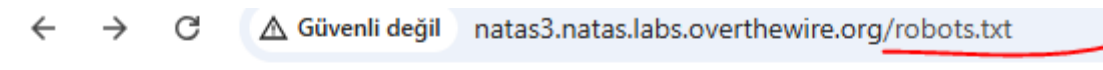
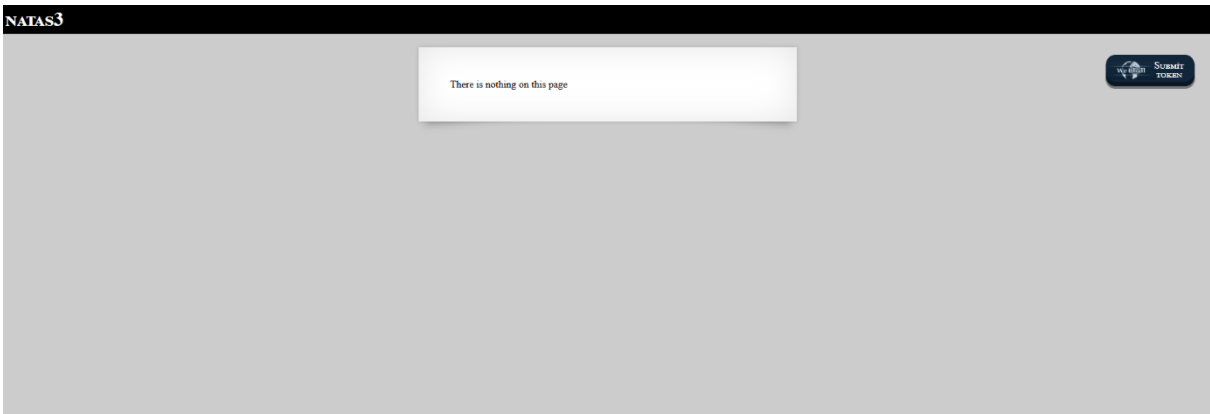
Çözüm 0. Bölümün aynısı.

NATAS2



Şifre /files/users.txt içerisinde gizli.

NATAS3



```
User-agent: *  
Disallow: /s3cr3t/
```

Robots.txt içerisinde s3cr3t adında bir dizin olduğunu öğreniyoruz.

Index of /s3cr3t

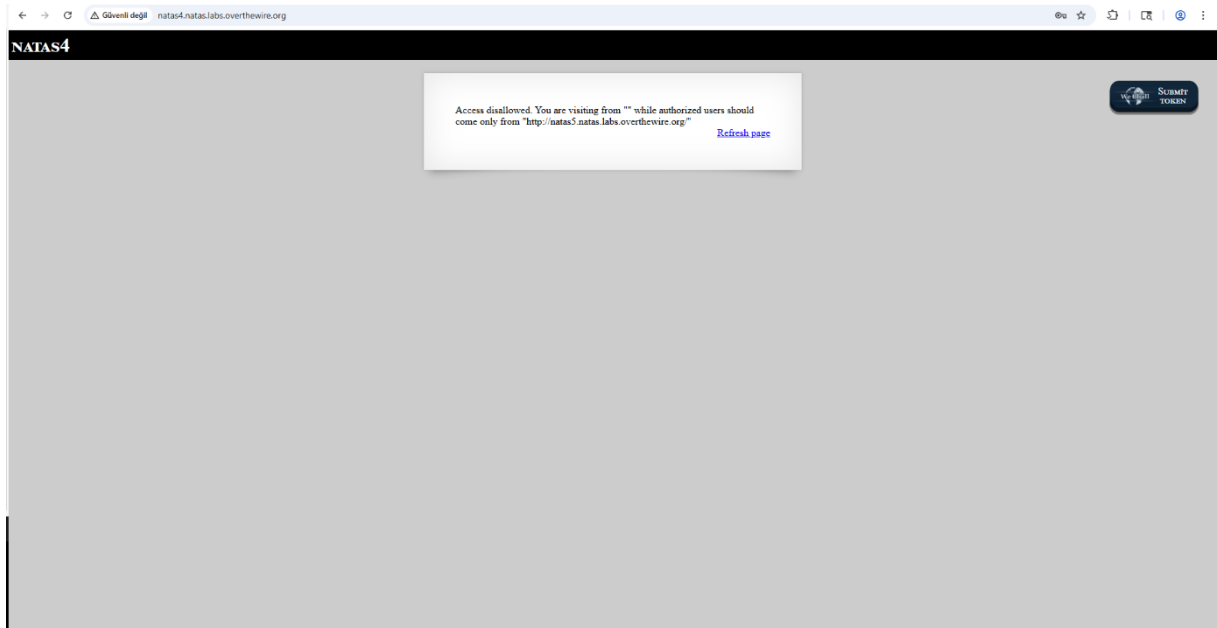
<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory	-	-	-
 users.txt	2025-10-14 09:06	40	

Apache/2.4.58 (Ubuntu) Server at natas3.natas.labs.overthewire.org Port 80

natas4:QryZXc2e0zahULdHrtHxzyYkj59kUxLQ

Şifre içerisindeki txt dosyasındadır

NATAS4



Erişim reddedildi, izinli kullanıcılar

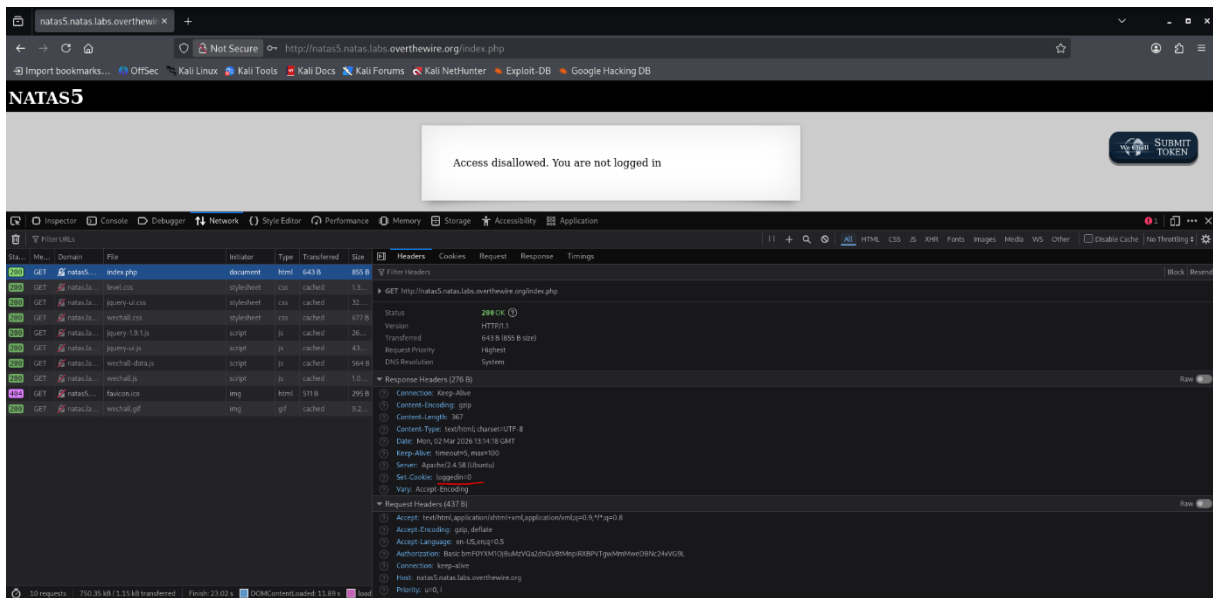
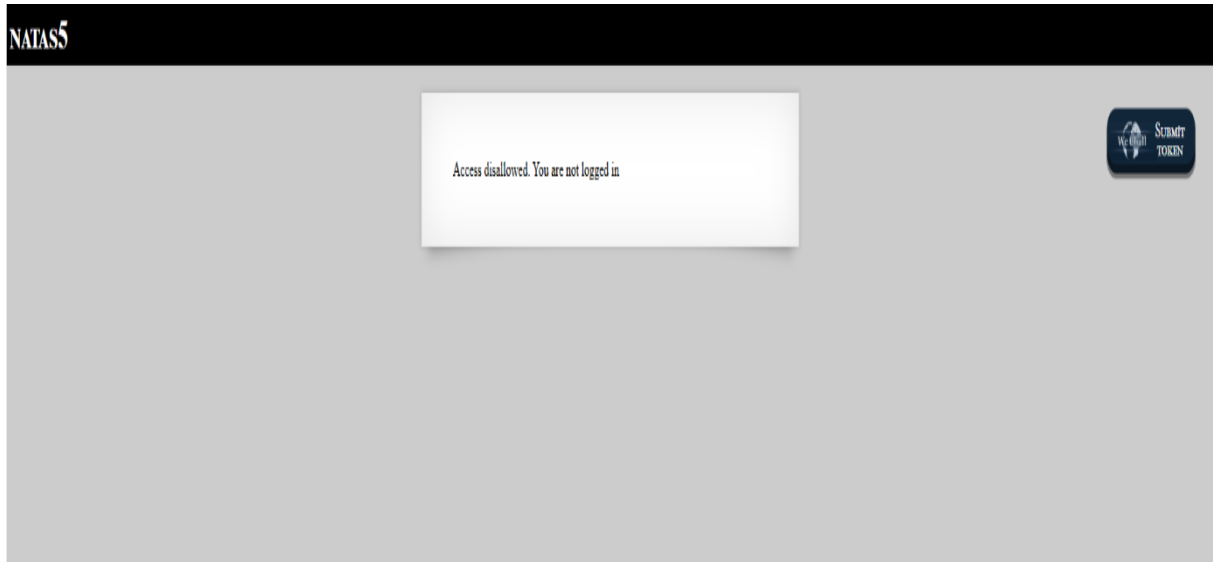
The screenshot shows the Burp Suite interface. At the top, there's a navigation bar with tabs: Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. Below this is a sub-bar with 'Intercept' and 'HTTP history' tabs. The 'HTTP history' tab is active, showing a list of requests. The first request is highlighted, showing details for a GET request to `http://natas4.natas.labs.overthewire.org/index.php`. The status is 401 Unauthorized. Below the history list, the 'Request' and 'Response' tabs are visible. The 'Request' tab shows the raw HTTP request, and the 'Response' tab shows the raw HTTP response. The response is a 401 Unauthorized status with a message: 'Access disallowed. You are visiting from "http://natas4.natas.labs.overthewire.org/" while authorized users should come only from "http://natas5.natas.labs.overthewire.org/"'. The 'Inspector' tab on the right shows the request headers and response headers.

natas5 adresinden gelmelidir mesajı yazıyor.

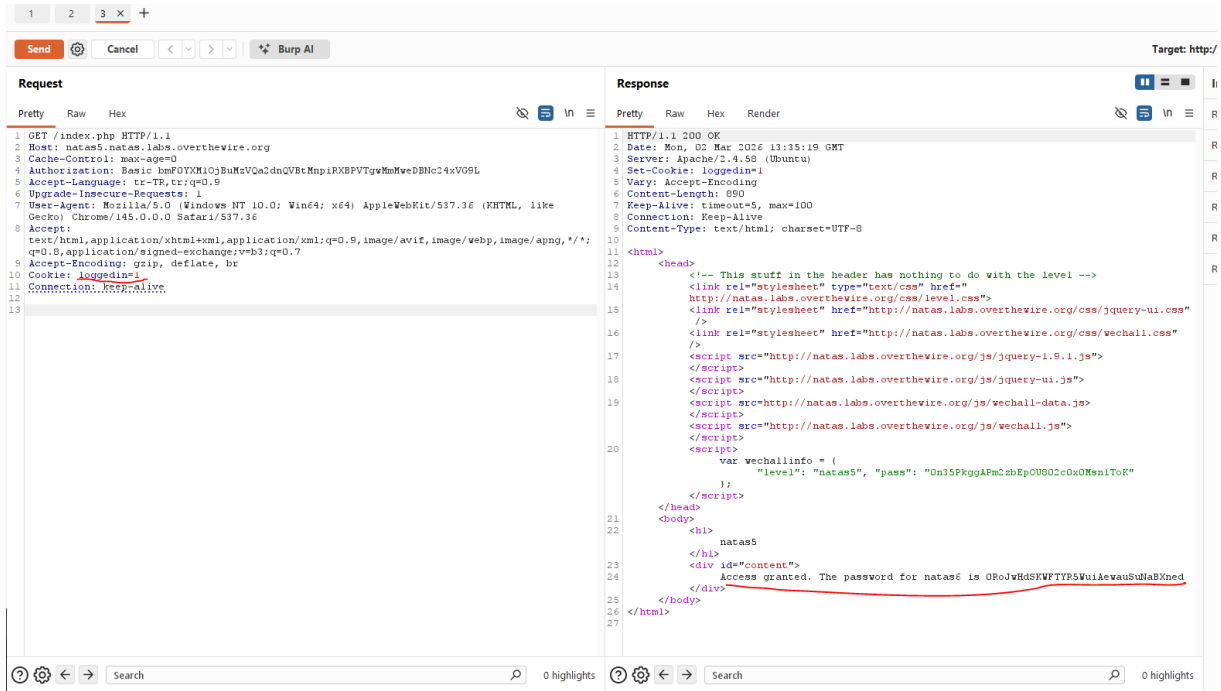
The screenshot shows the Burp Suite interface. At the top, there's a navigation bar with tabs: Dashboard, Target, Proxy, Intruder, Repeater, Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. Below this is a sub-bar with 'Send' and 'Cancel' buttons. The 'Send' button is active, showing details for a GET request to `http://natas5.natas.labs.overthewire.org/index.php`. The status is 200 OK. Below the history list, the 'Request' and 'Response' tabs are visible. The 'Request' tab shows the raw HTTP request, and the 'Response' tab shows the raw HTTP response. The response is a 200 OK status with a message: 'Access granted. The password for natas5 is On35PkggAFm2zbEpOU802c0x0Msn1ToR'. The 'Inspector' tab on the right shows the request headers and response headers.

GET metodlu isteği repeater içerisine yolladım. Sonra referer kısmındaki adresi değiştirip bölümün başında belirtilen natas5 adresini yazdım. Bununla birlikte site benim o adresten geldiğimi sandı ve şifreyi aldım.

NATAS5

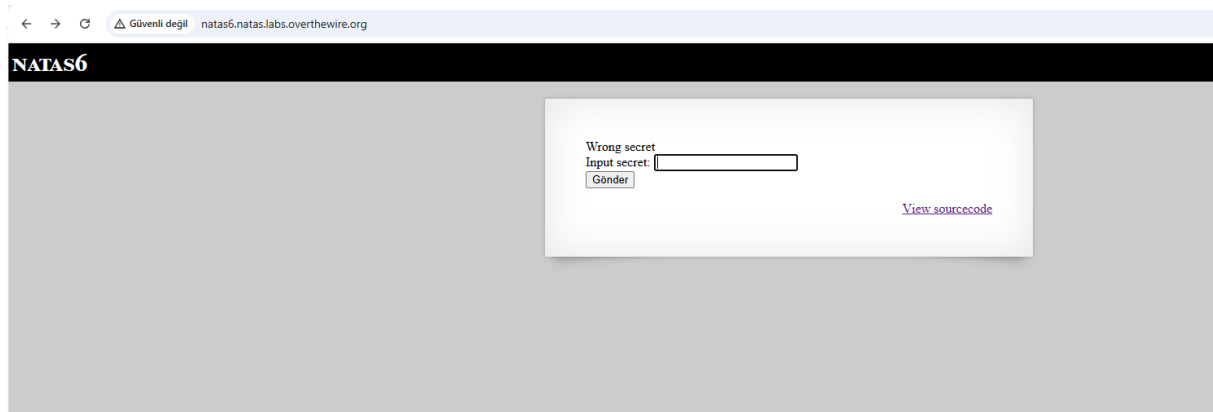


Bu bölümde cookie değerinin loggedin=0 olduğunu görüyoruz.



Cookie'deki loggedin=0 değerini 1 yaptığımız zaman bir sonraki bölümün şifresini elde ediyoruz.

NATAS6



Secret girdi alanı görüyoruz. Yanlış girdiğimizde yanlış secret diyor. Sayfanın kaynak koduna bakıyorum.

```
<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src="http://natas.labs.overthewire.org/js/wechall-data.js"></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas6", "pass": "<censored>" };</script></head>
<body>
<h1>natas6</h1>
<div id="content">
<?
include "includes/secret.inc";

if(array_key_exists("submit", $_POST)) {
    if($_secret == $_POST['secret']) {
        print "Access granted. The password for natas7 is <censored>";
    } else {
        print "Wrong secret";
    }
}
?>

<form method=post>
Input secret: <input name=secret><br>
<input type=submit name=submit>
</form>

<div id="viewsource"><a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```

Burada includes/secret.inc diye bir dizin gördüm ve direkt gözüme takıldı.

```
<?
$_secret = "FOEIUWGHFEEUHOFOUIU";
?>
```

Direkt olarak düz mantık ile dizini açtığımız zaman bir secret görüyoruz.

Dashboard Target Proxy Intruder **Repeater** Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 3 **4 X** +

Send Cancel < > Burp AI Target: h

Request

Pretty Raw Hex

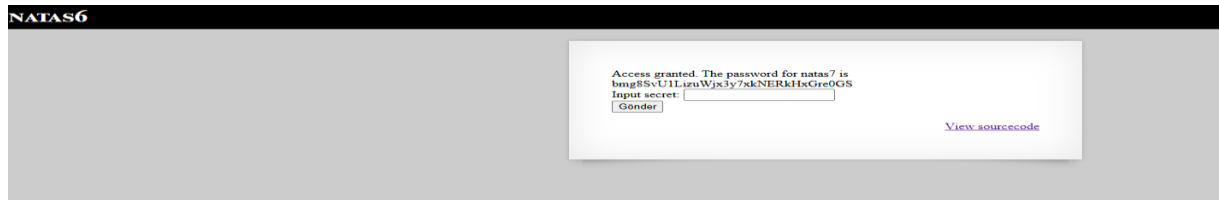
```
1 POST / HTTP/1.1
2 Host: natas6.natas.labs.overthewire.org
3 Content-Length: 45
4 Cache-Control: max-age=0
5 Authorization: Basic
6 bmf0YXNjBShOp3SGRTSldGVFI5NVdlaUFlId2F1U3VOYUJYbmVh
7 Accept-Language: tr-TR, tr;q=0.9
8 Origin: http://natas6.natas.labs.overthewire.org
9 Content-Type: application/x-www-form-urlencoded
10 Upgrade-Insecure-Requests: 1
11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
12 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
13 Accept:
14 text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/
15 webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
16 Referer: http://natas6.natas.labs.overthewire.org/
17 Accept-Encoding: gzip, deflate, br
18 Connection: keep-alive
19 secret=FOEIUWGHFEEUHOFOUOIU&submit=G4C3%B6nder
```

Response

Pretty Raw Hex Render

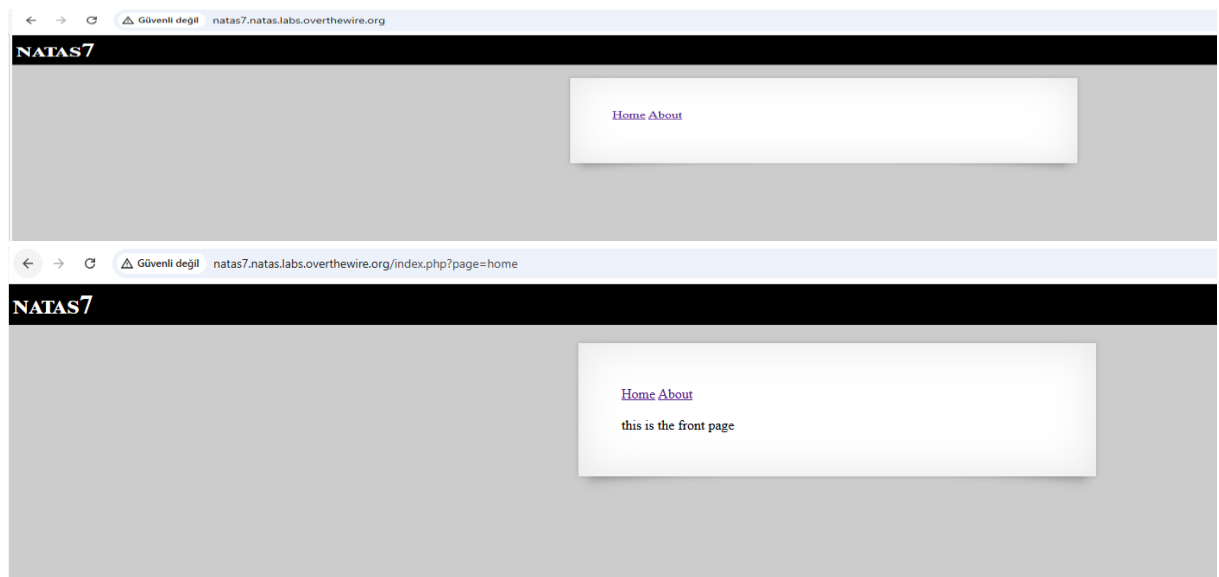
```
19 <script src="http://natas.labs.overthewire.org/js/wechall.js"
20 >
21 </script>
22 <script>
23     var wechallinfo = {
24         "level": "natas6", "pass":
25         "ORoJwHdSKWFTYR5WuiAewauSuNaBXned"
26     };
27 </script>
28 </head>
29 <body>
30 <h1>
31     natas6
32 </h1>
33 <div id="content">
34     Access granted. The password for natas7 is
35     bmg8SvU1LizuWjx3y7xkNERkHxGre0GS
36 <form method=post>
37     Input secret: <input name=secret>
38     <br>
39     <input type=submit name=submit>
40 </form>
41
42 <div id="viewsource">
43     <a href="index-source.html">
44         View sourcecode
45     </a>
46 </div>
47 </div>
48 </body>
49 </html>
```

Secret alanına aldığımız secret değerini koyduğumuz zaman şifre elimizde.



Burp şart değil tabikide.

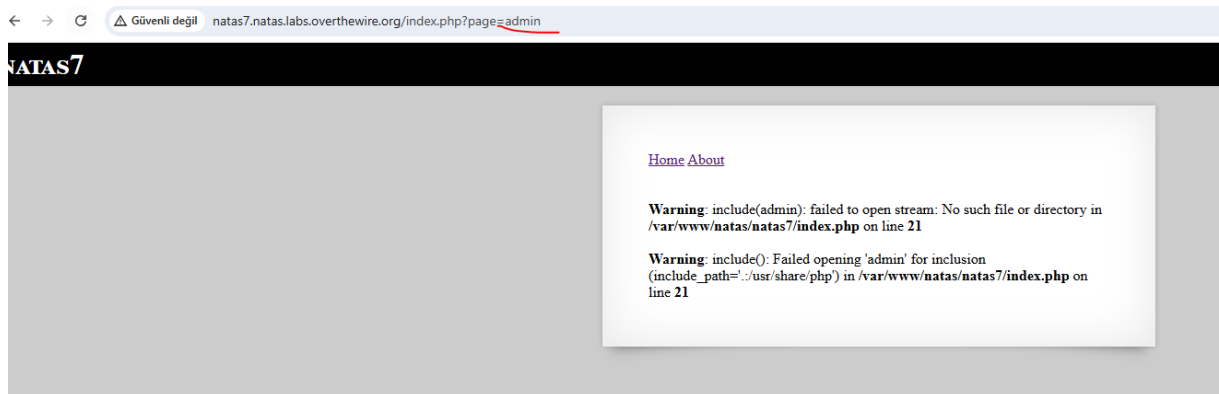
NATAS7



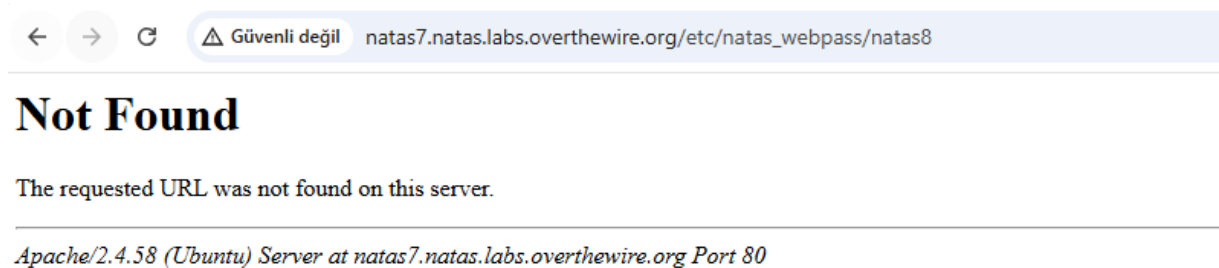
Satır kaydır ☐

```
1 <html>
2 <head>
3 <!-- This stuff in the header has nothing to do with the level -->
4 <link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
5 <link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
6 <link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
7 <script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
8 <script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
9 <script src="http://natas.labs.overthewire.org/js/wechall-data.js"></script><script src="http://nat
10 <script>var wechallinfo = { "level": "natas7", "pass": "bmg8SvU1LizuWjx3y7xkNERkHxGre0GS" };</scr
11 <body>
12 <h1>natas7</h1>
13 <div id="content">
14
15 <a href="index.php?page=home">Home</a>
16 <a href="index.php?page=about">About</a>
17 <br>
18 <br>
19 this is the about page
20
21 <!-- hint: password for webuser natas8 is in /etc/natas_webpass/natas8 -->
22 </div>
23 </body>
24 </html>
25
```

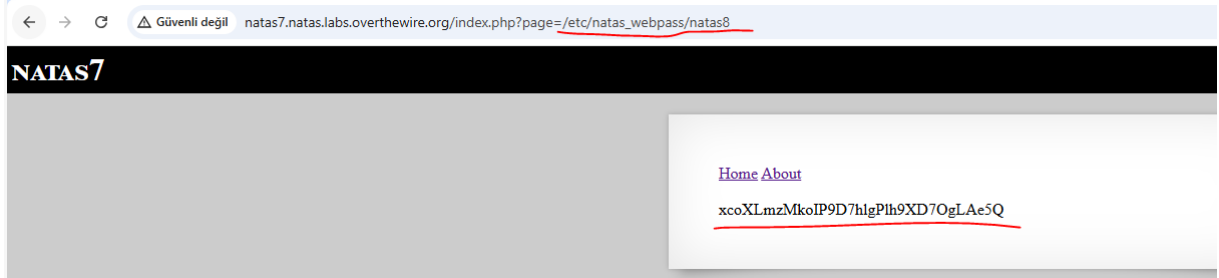
Kaynak kodunda bir hint alıyoruz.



Burda rastgele bir veri girdim “admin” ve bize yararlı olabilecek birkaç çıktı geldi.

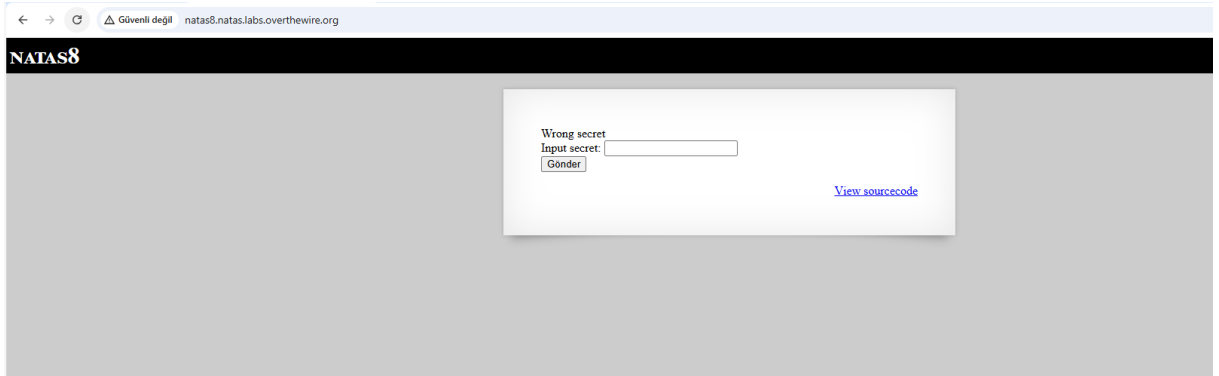


Burada verilen hinti denedim ama sonuç yok.



Burada yaptığım hata verilen hinti file path olarak denemem olmuş. Verilen hinti gidip parametre alanına koyduğumuz zaman bir sonraki bölümün şifresini elde ediyoruz.

NATAS8



Tekrardan doğru secret'ı bulmamız istenilen bir bölüm.


```
← → ↻ Güvenli değil natas8.natas.labs.overthewire.org/index-source.html

<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src="http://natas.labs.overthewire.org/js/wechall-data.js"></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas8", "pass": "<censored>" };</script></head>
<body>
<h1>natas8</h1>
<div id="content">

<?

$encodedSecret = "3d3d516343746d4d6d6c315669563362";

function encodeSecret($secret) {
    return bin2hex(strrev(base64_encode($secret)));
}

if(array_key_exists("submit", $_POST)) {
    if(encodeSecret($_POST['secret']) == $encodedSecret) {
        print "Access granted. The password for natas9 is <censored>";
    } else {
        print "Wrong secret";
    }
}
?>

<form method=post>
Input secret: <input name=secret><br>
<input type=submit name=submit>
</form>

<div id="viewsource"><a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```

Source kodu görüntüle dediğimiz zaman bir ipucu görüyoruz. İpucu:

```
<?

$encodedSecret = "3d3d516343746d4d6d6c315669563362";

function encodeSecret($secret) {
    return bin2hex(strrev(base64_encode($secret)));
}

if(array_key_exists("submit", $_POST)) {
    if(encodeSecret($_POST['secret']) == $encodedSecret) {
        print "Access granted. The password for natas9 is <censored>";
    } else {
        print "Wrong secret";
    }
}
?>
```

Return bin2hex(strrev(base64_encode(\$secret)));

Bu satırın anlamı içeriden dışarıya doğru encode edildiğidir. Bunu decode edersek bir yere varabiliriz.

Hex to String Converter

Enter hex code bytes with any prefix / postfix / delimiter and press the *Convert* button
(e.g. 45 78 61 6d 70 6C 65 21):

From

Hexadecimal

To

Text

Open File

Sample

Paste hex code numbers or drop file

3d3d516343746d4d6d6c315669563362

Character encoding

ASCII

= Convert

× Reset

↕ Swap

==QcCtmMml1ViV3b

En son on altılı sayı sistemine çevirilmiş ilk olarak onu decode ediyoruz.

Strrev ise ters çevirme anlamına geliyor çıktığı ters çeviriyoruz.

b3ViV1lmMmtCcQ==|

Input

`b3ViV1lmMmtCcQ==`

Output

`oubWYf2kBq`

Son olarak base64 decode ediyoruz.

Güvenli değil

natas8.natas.labs.overthewire.org

NATAS8

Access granted. The password for natas9 is
ZE1ck82lmdGioErlhQgWND6j2Wzz6b6t
Input secret:

[View sourcecode](#)

Çıkan sonucu girdiye yazdığımız zaman 9. Bölümün şifresini elde ediyoruz.

NATAS9

NATAS9

Find words containing:

Output: [View sourcecode](#)

```
← → ↺ ⚠ Güvenli değil natas9.natas.labs.overthewire.org/index-source.html

<html>
<head>
<!-- This stuff in the header has nothing to do with the level -->
<link rel="stylesheet" type="text/css" href="http://natas.labs.overthewire.org/css/level.css">
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/jquery-ui.css" />
<link rel="stylesheet" href="http://natas.labs.overthewire.org/css/wechall.css" />
<script src="http://natas.labs.overthewire.org/js/jquery-1.9.1.js"></script>
<script src="http://natas.labs.overthewire.org/js/jquery-ui.js"></script>
<script src="http://natas.labs.overthewire.org/js/wechall-data.js"></script><script src="http://natas.labs.overthewire.org/js/wechall.js"></script>
<script>var wechallinfo = { "level": "natas9", "pass": "<censored>" };</script></head>
<body>
<h1>natas9</h1>
<div id="content">
<form>
Find words containing: <input name="needle"><input type="submit" name="submit" value="Search"><br><br>
</form>

Output:
<pre>
<?
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

if($key != "") {
    passthru("grep -i $key dictionary.txt");
}
?>
</pre>

<div id="viewsource"><a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```

Burada command injection var. Kısaca bizim girdilerimiz komut olarak algılıyor bu da görmememiz gereken verileri görebilme şansı veriyor bize.

Bu koddaki sıkıntılı kısım şurasıdır:

```
$key = "";

if(array_key_exists("needle", $_REQUEST)) {

    $key = $_REQUEST["needle"];

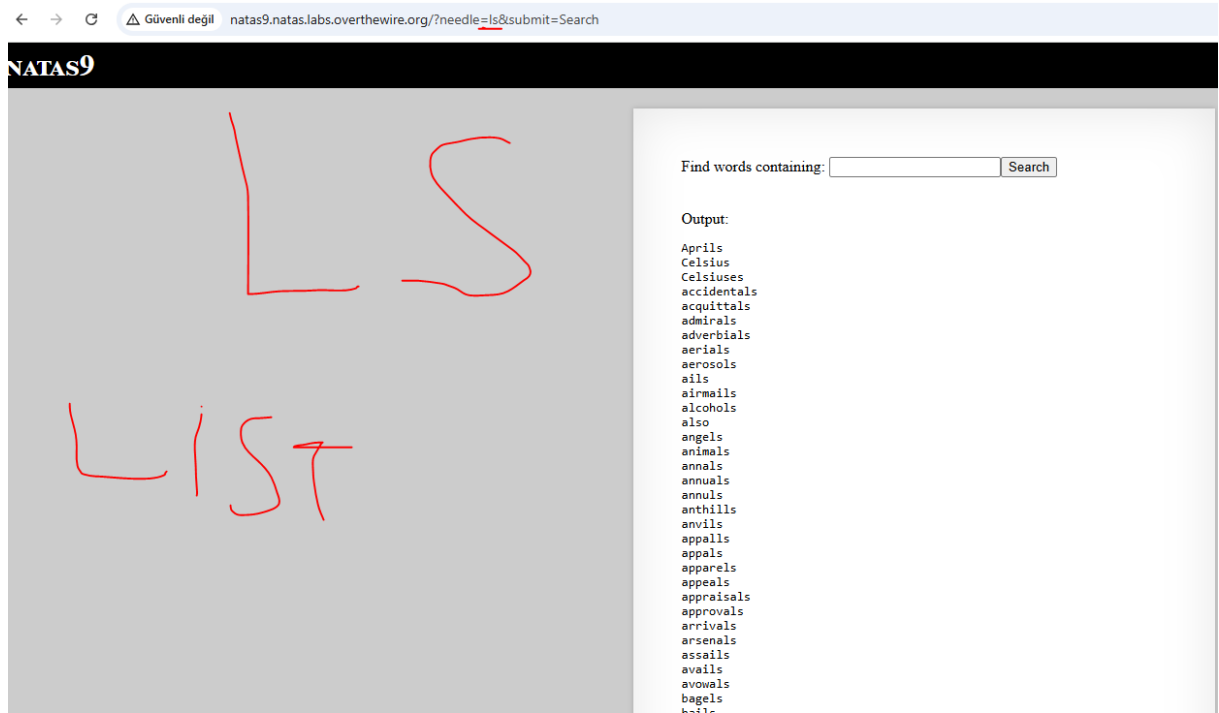
}

if($key != "") {

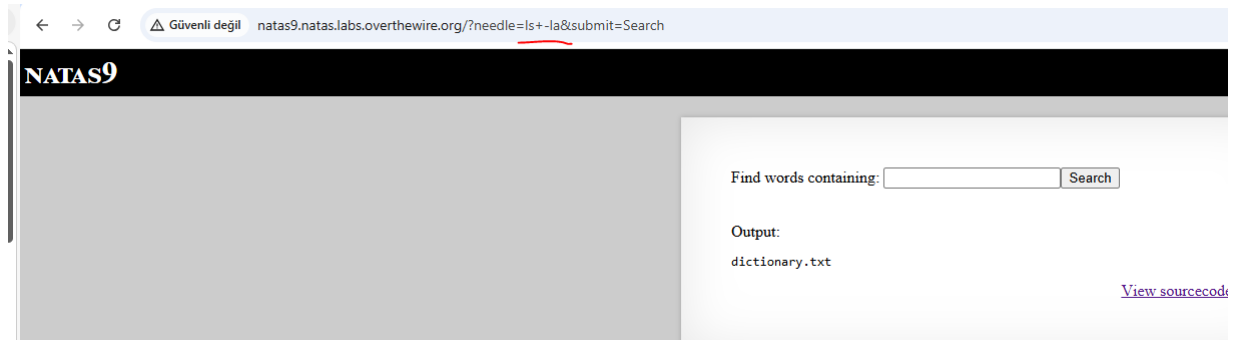
    passthru("grep -i $key dictionary.txt");

}
```

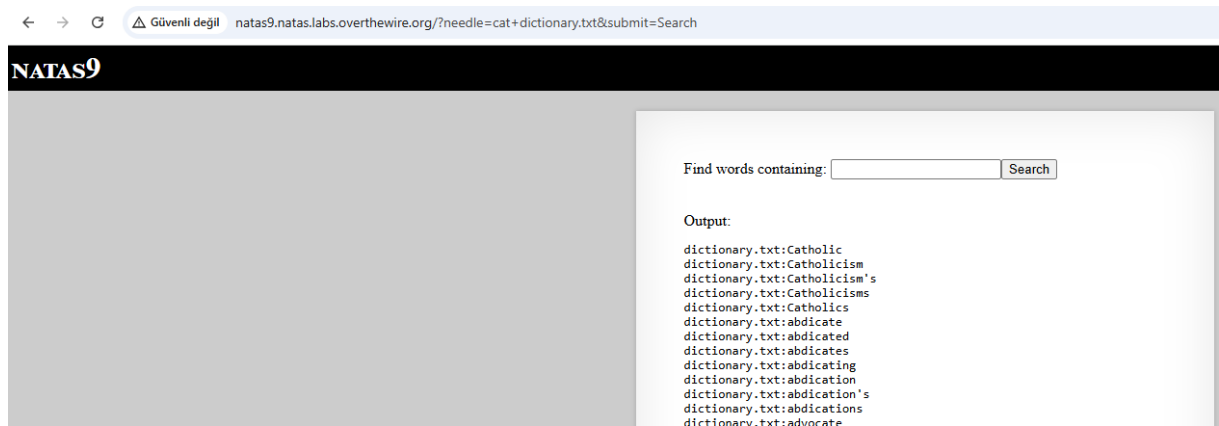
Passthru = php ile Shell komutlarını çalıştırmak içindir (bash, ls, mv, mkdir, cat vb...)



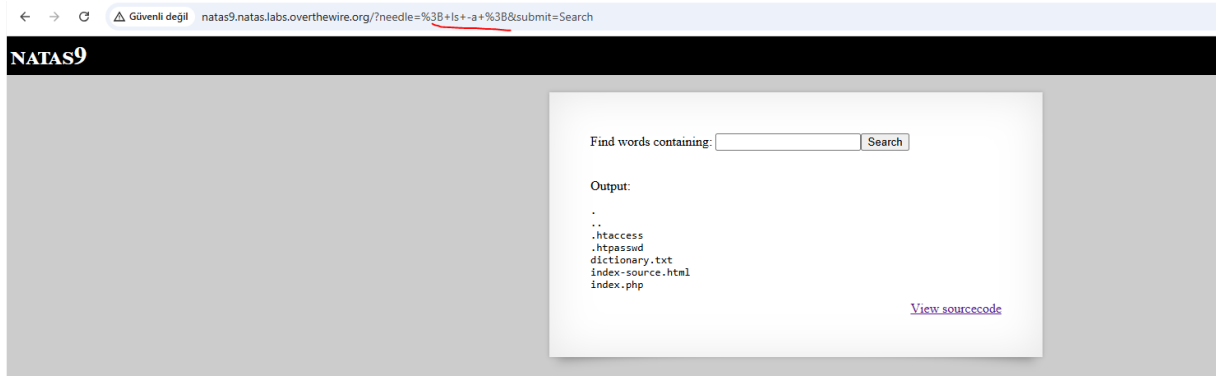
Ls yani list yazdığımda (url'de gözüktüğü gibi) bir şey olmadı.



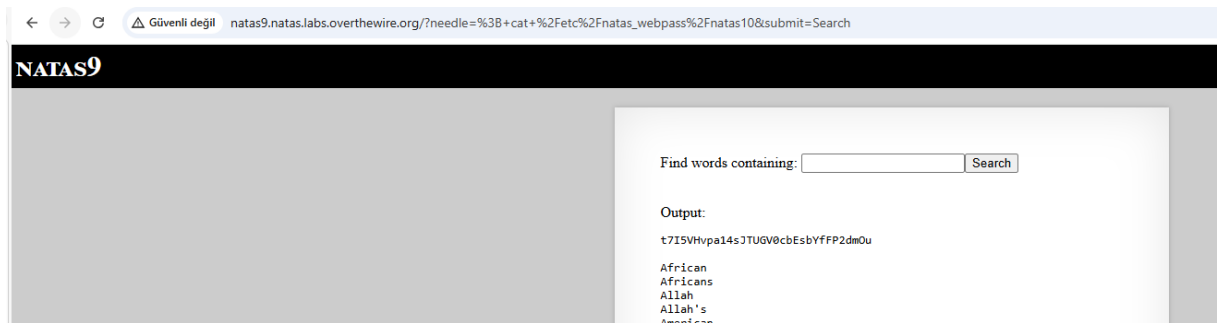
Burada ls -la denedim.



Burada cat ile dictionary.txt dosyasını okumayı denedim.



Burada ; ls -a yaptım ve sonuç çok daha farklı. Şimdi neden ; eklediğimizde dosyaları görebildiğimizi anlatayım. Bu sitede girdi şu şekilde çalışıyor grep -i. Kullanıcıya x değerini göster diyor. Biz noktalı virgül koyduğumuz zaman aslında grep komutunun önüne bir duvar koyuyoruz, yani komutu ayırıyoruz. Yani noktalı virgül ile komut ayrımı yapıp noktalı virgül sonrasında istediğimiz komutu girebiliyoruz.



Bölümdeki next level anahtarları /etc/natas_webpass/natas"sayı" dizinlerindeydi. O yüzden cat komutu ile /etc/natas_webpass/natas10 dizinindeki dosyaya bakmak en mantıklısı.

; cat /etc/natas_webpass/natas10 ile şifreyi alıyoruz

NATAS10

```
Find words containing: <input name=needle><input type=submit name=submit value=Search</form>

Output:
<pre>
<?
$key = "";

if(array_key_exists("needle", $_REQUEST)) {
    $key = $_REQUEST["needle"];
}

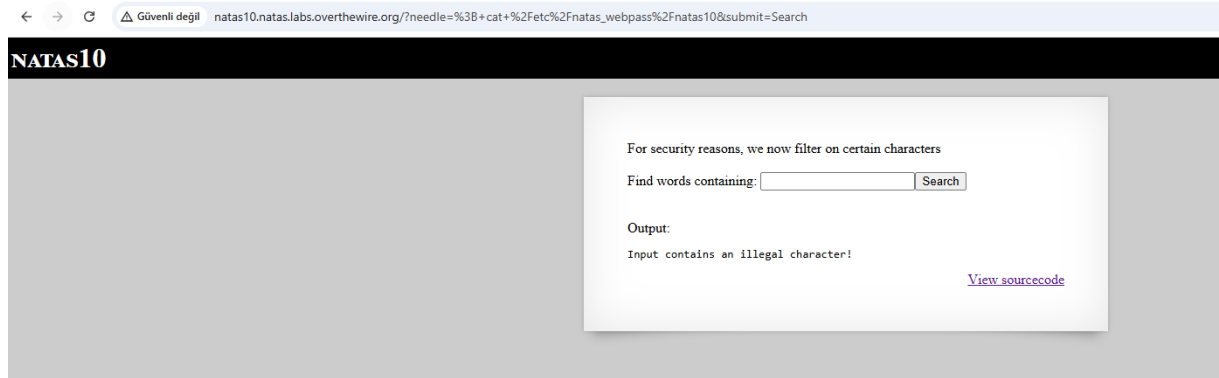
if($key != "") {
    if(preg_match('/[;|&|/]', $key)) {
        print "Input contains an illegal character!";
    } else {
        passthru("grep -i $key dictionary.txt");
    }
}
?>
</pre>

<div id="viewsource"><a href="index-source.html">View sourcecode</a></div>
</div>
</body>
</html>
```

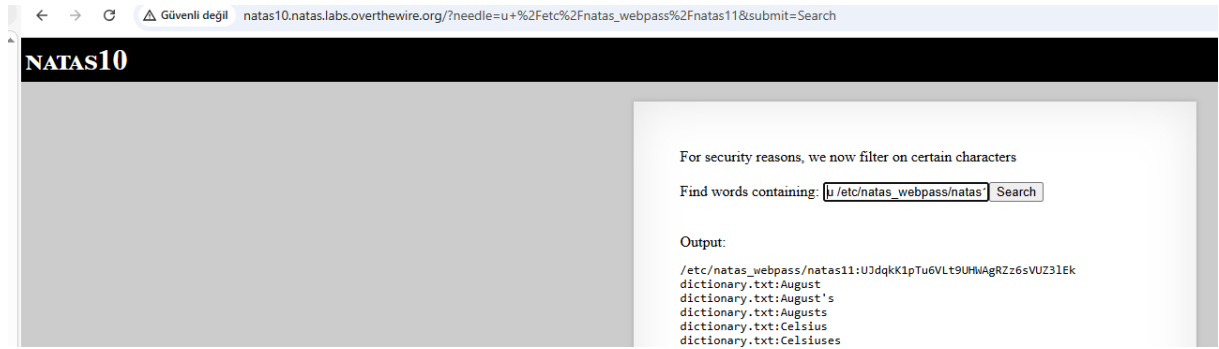
9 ile aynı mantıkta bir bölüm direkt kaynak kodu bize sunuyor.

Bu bölümde ise yine command injection var ama bu sefer filtrelenmiş filtreyi bypasslememiz gerekiyor.

`preg_match('/:|&|/',$key)` kısmı kullandığımız noktalı virgül gibi işaretleri engelliyor.



Denediğimde zaten bu girdi yasaklı karakter içeriyor çıktısını aldım.



Burada ne oldu da şifreyi aldık anlatayım. Söylediğim gibi burada filtreleme var belirli karakterleri girmemize izin vermiyor. Kodun çalışma mantığına bakmadan önce girdiğimiz payload/girdi'ye bakalım.

`u /etc/natas_webpass/natas11`

Sunucu tarafında asıl çalışan komut:

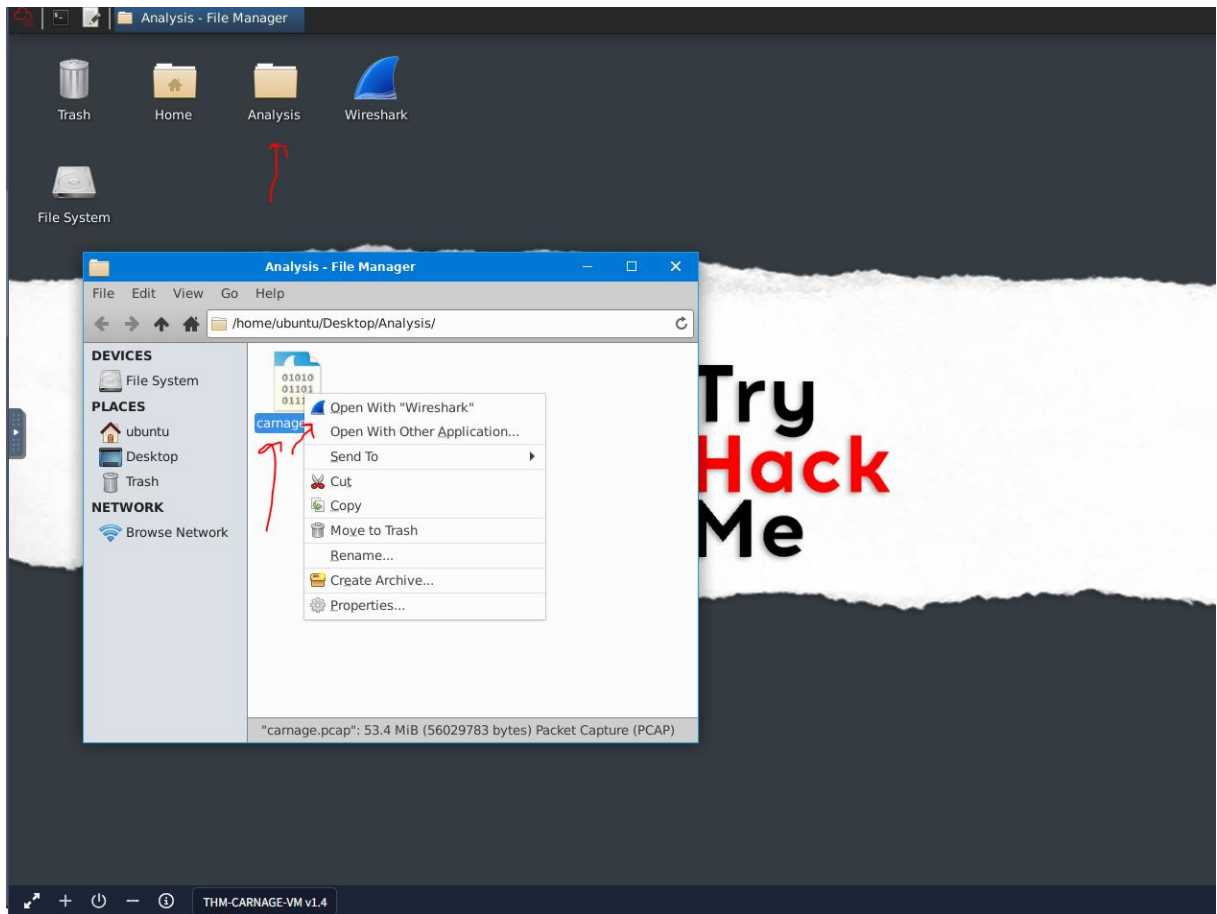
`grep -i u dictionary.txt /etc/natas_webpass/natas11`. Yani burada sunucu hem dictionary hemde natas11 için arama yapmaktadır. Bu da bir command injection örneği.

Cephe 3: Kör Nokta Dedektifi (Ağ Adli Analizi)

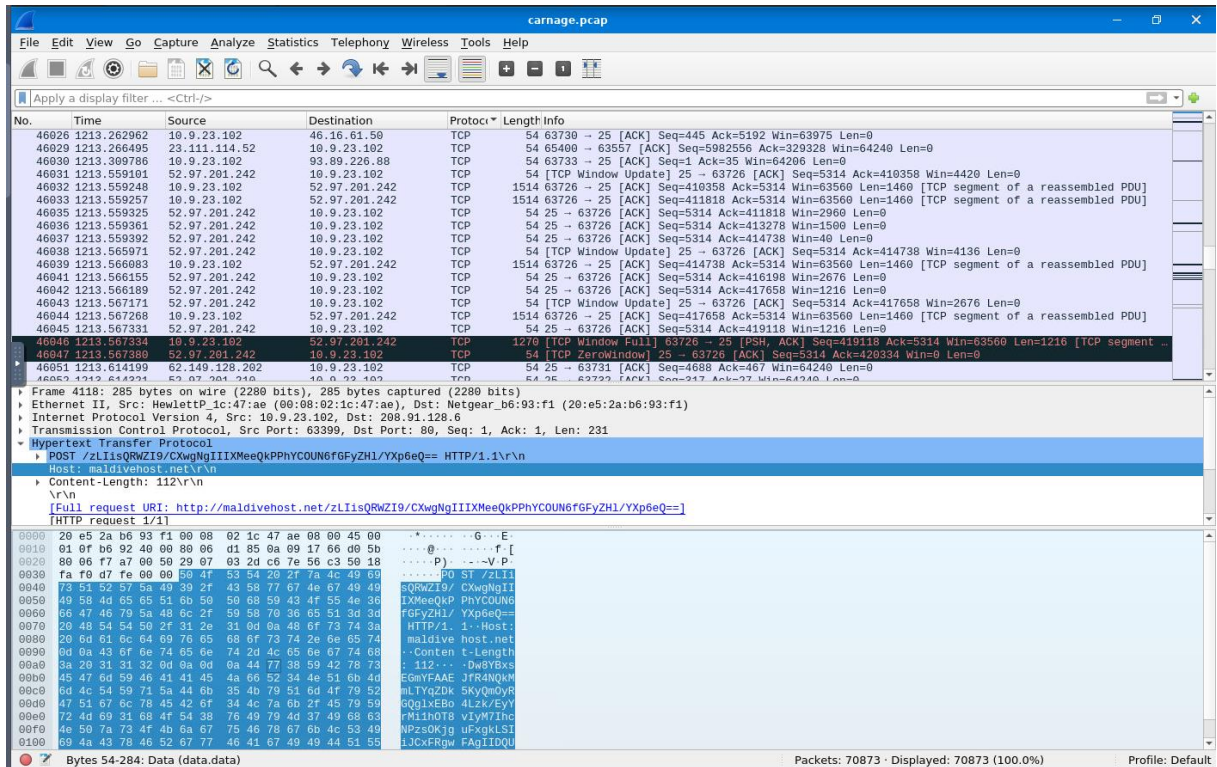
C2 Carnage

Satın alma departmanından Eric Fischer, bilinen bir kişiden gelen e-postadaki Word belgesini açıp yanlışlıkla "İçeriği Etkinleştir" butonuna tıkladı. SOC ekibi anında şüpheli dış bağlantı alarmları aldı ve ağ sensöründen alınan PCAP dosyasını bize etti.

Şimdi bu thm makinesini çözeceğiz. Bu makine bu raporun başında konuştuğumuz pcap analizi, paket analizi, C2 sunucuları hakkında olacak.



Try
Hack
Me



Bize verilen pcap dosyasını wireshark üstünden açtım.

Room progress (4%)

Are you ready for the journey?

Please, load the pcap file in your Analysis folder on the Desktop into Wireshark to answer the questions below.

Answer the questions below

What was the date and time for the first HTTP connection to the malicious IP?

(answer format: yyyy-mm-dd hh:mm:ss)

Answer format: *****

Check

What is the name of the zip file that was downloaded?

Answer format: *****

Check

What was the domain hosting the malicious zip file?

Answer format: *****

Check

Without downloading the file, what is the name of the file in

Wireshark

Apply a display filter... <Ctrl>F

Appearance Columns Displayed Title

Font and Color

Layout

Capture

Expert

Filter Buttons

Name Resolution

Length

Info

Protocols

Statistics

Advanced

Destination port

Expert Info Severity

FW-1 monitor #direction

Frequency/Channel

Hardware dest addr

Hardware src addr

HW dest addr (resolved)

HW dest addr (unresolved)

HW dest addr (resolved)

HW src addr (resolved)

HW src addr (unresolved)

IEEE 802.11 RSSI

IEEE 802.11 TX rate

Protocol

IP DSCP Value

Information

Net dest addr (resolved)

Net dest addr (unresolved)

Net src addr (resolved)

Net src addr (unresolved)

Network dest addr

Network src addr

Number

Packet length (bytes)

Protocol

Relative time

Source address

Source port

Src addr (resolved)

Src addr (unresolved)

Src port (resolved)

Src port (unresolved)

TEI

UTC date, as YYYY-MM-DD, and time

UTC date, as YYYY/DDV, and time

UTC time

Time (format as specified)

7873 - Displayed: 70873 (100.0%) Profile: Default

İlk soru bize c2 sunucusundan gelen ilk http bağlantısını sorduğu için tarih ve zaman'ı en detaylı halimde açıyorum.

Room progress (9%)

Are you ready for the journey?

Please, load the pcap file in your Analysis folder on the Desktop into Wireshark to answer the questions below.

Answer the questions below

What was the date and time for the first HTTP connection to the malicious IP?

(answer format: yyyy-mm-dd hh:mm:ss)

2021-09-24 16:49:38

Correct Answer

What is the name of the zip file that was downloaded?

Answer format: *****

Check

What was the domain hosting the malicious zip file?

Answer format: *****

Check

Without downloading the file, what is the name of the file in

Wireshark

Apply a display filter... <Ctrl>F

Appearance Columns Displayed Title

Font and Color

Layout

Capture

Expert

Filter Buttons

Name Resolution

Length

Info

Protocols

Statistics

Advanced

Destination port

Expert Info Severity

FW-1 monitor #direction

Frequency/Channel

Hardware dest addr

Hardware src addr

HW dest addr (resolved)

HW dest addr (unresolved)

HW dest addr (resolved)

HW src addr (resolved)

HW src addr (unresolved)

IEEE 802.11 RSSI

IEEE 802.11 TX rate

Protocol

IP DSCP Value

Information

Net dest addr (resolved)

Net dest addr (unresolved)

Net src addr (resolved)

Net src addr (unresolved)

Network dest addr

Network src addr

Number

Packet length (bytes)

Protocol

Relative time

Source address

Source port

Src addr (resolved)

Src addr (unresolved)

Src port (resolved)

Src port (unresolved)

TEI

UTC date, as YYYY-MM-DD, and time

UTC date, as YYYY/DDV, and time

UTC time

Time (format as specified)

7873 - Displayed: 70873 (100.0%) Profile: Default

http olarak filtreleyip zamanı azdan fazla olarak filtrelediğim zaman bunu buldum.

Room progress (14%)

Are you ready for the journey?

Please, load the pcap file in your Analysis folder on the Desktop into Wireshark to answer the questions below.

Answer the questions below

What was the date and time for the first HTTP connection to the malicious IP?

(answer format: yyyy-mm-dd hh:mm:ss)

2021-09-24 16:49:38

Correct Answer

What is the name of the zip file that was downloaded?

documents.zip

Correct Answer

What was the domain hosting the malicious zip file?

Answer format: *****

Check

Without downloading the file, what is the name of the file in

Wireshark

Apply a display filter... <Ctrl>F

Appearance Columns Displayed Title

Font and Color

Layout

Capture

Expert

Filter Buttons

Name Resolution

Length

Info

Protocols

Statistics

Advanced

Destination port

Expert Info Severity

FW-1 monitor #direction

Frequency/Channel

Hardware dest addr

Hardware src addr

HW dest addr (resolved)

HW dest addr (unresolved)

HW dest addr (resolved)

HW src addr (resolved)

HW src addr (unresolved)

IEEE 802.11 RSSI

IEEE 802.11 TX rate

Protocol

IP DSCP Value

Information

Net dest addr (resolved)

Net dest addr (unresolved)

Net src addr (resolved)

Net src addr (unresolved)

Network dest addr

Network src addr

Number

Packet length (bytes)

Protocol

Relative time

Source address

Source port

Src addr (resolved)

Src addr (unresolved)

Src port (resolved)

Src port (unresolved)

TEI

UTC date, as YYYY-MM-DD, and time

UTC date, as YYYY/DDV, and time

UTC time

Time (format as specified)

7873 - Displayed: 70873 (100.0%) Profile: Default

İndirilen zip dosyasının adını sormuş. http alanını açıp bu bilgiyi görebiliyoruz.

Are you ready for the journey?

Please, load the pcap file in your Analysis folder on the Desktop into Wireshark to answer the questions below.

Answer the questions below

What was the date and time for the first HTTP connection to the malicious IP?

(answer format: yyyy-mm-dd hh:mm:ss)

2021-09-24 10:44:38

Correct Answer

What is the name of the zip file that was downloaded?

documents.zip

Correct Answer

What was the domain hosting the malicious zip file?

attirenepal.com

Correct Answer

Without downloading the file, what is the name of the file in the zip file?

Answer format: *****

Wireshark - Client Leader Window - Analysis - File Manager

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

http

No.	Time	Source	Destination	Protocol	Length	Info
4850	2021-09-24 10:40:12.767612	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4846	2021-09-24 10:40:11.959706	208.91.128.6	10.9.23.102	HTTP	285	POST /z/1110qWZ19/DC127Ts3Dga/A1cErqKXh5ERX5ZKJ1fXkxex9 HTTP/1.1 Continuat
4841	2021-09-24 10:40:47.677039	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4837	2021-09-24 10:40:46.858457	208.91.128.6	10.9.23.102	HTTP	271	POST /z/1110qWZ19/A4uZ1t/M63FV2Z38Zxt7rq= HTTP/1.1 Continuation
4831	2021-09-24 10:40:22.534972	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4827	2021-09-24 10:40:21.085873	208.91.128.6	10.9.23.102	HTTP	289	POST /z/1110qWZ19/H0M8N5AA4ndp6EPM10/7J1E5Z6ewVYX15ZK1/q= HTTP/1.1 Contim
4821	2021-09-24 10:47:57.518193	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4817	2021-09-24 10:47:56.779139	208.91.128.6	10.9.23.102	HTTP	293	POST /z/1110qWZ19/1j1-35oqQ4181w/AR7KngV4gopK9fNtkcJ9eG8Fth= HTTP/1.1 Cor
4810	2021-09-24 10:47:32.338466	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
4806	2021-09-24 10:47:33.584345	208.91.128.6	10.9.23.102	HTTP	273	POST /z/1110qWZ19/e0kAAAbInx9bhp6ZVhxeK1fX9S HTTP/1.1 Continuation
4800	2021-09-24 10:47:07.267952	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3996	2021-09-24 10:47:06.571342	208.91.128.6	10.9.23.102	HTTP	285	POST /z/1110qWZ19/F0M8N5AA4ndp6EPM10/7J1E5Z6ewVYX15ZK1/q= HTTP/1.1 Continuat
3912	2021-09-24 10:46:42.285190	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3908	2021-09-24 10:46:41.509897	208.91.128.6	10.9.23.102	HTTP	285	POST /z/1110qWZ19/ASdSAuSf8R11/EseTgKcn6FGFY2H1/Yxp6e= HTTP/1.1 Continuat
3851	2021-09-24 10:46:17.143575	208.91.128.6	10.9.23.102	HTTP	634	HTTP/1.1 200 OK (text/html)
3822	2021-09-24 10:46:18.363900	208.91.128.6	10.9.23.102	HTTP	281	POST /z/1110qWZ19/Qqad1zchTgFjMc0pGden1duF5eW9f3k= HTTP/1.1 Continuation
2173	2021-09-24 10:44:41.970937	85.187.128.24	10.9.23.102	HTTP	589	HTTP/1.1 200 OK
7189	2021-09-24 10:44:38.972472	104.72.243.24	10.9.23.102	HTTP	514	GET /incidunt-consequatur/documents.zip HTTP/1.1

Transmission Control Protocol, Src Port: 62245, Dst Port: 80, Seq: 1, Ack: 1, Len: 460

Hypertext Transfer Protocol

GET /incidunt-consequatur/documents.zip HTTP/1.1 r/vn

[Expert Info (Chat/Sequence): GET /incidunt-consequatur/documents.zip HTTP/1.1 r/vn]

Request Method: GET

Request URI: /incidunt-consequatur/documents.zip

Request Version: HTTP/1.1

Host: attirenepal.com/vn

Connection: keep-alive

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.4577.82 Safari/537.36 Edg/93.0.961.52 r/vn

Zip dosyasının bulunduğu domaini sormuş. Aynı şekilde http alanından bulabiliyoruz.

(answer format: yyyy-mm-dd hh:mm:ss)

2021-09-24 10:44:38

Correct Answer

What is the name of the zip file that was downloaded?

documents.zip

Correct Answer

What was the domain hosting the malicious zip file?

attirenepal.com

Correct Answer

Without downloading the file, what is the name of the file in the zip file?

chart-1530076591.xls

Correct Answer

What is the name of the webserver of the malicious IP from which the zip file was downloaded?

LiteSpeed

Correct Answer

What is the version of the webserver from the previous question?

LiteSpeed

Wireshark - Follow TCP Stream (tcp.stream eq 73) - carnage.pcap

GET /incidunt-consequatur/documents.zip HTTP/1.1

Host: attirenepal.com

Connection: keep-alive

Upgrade-Insecure-Requests: 1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.4577.82 Safari/537.36 Edg/93.0.961.52

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/png,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9

Accept-Encoding: gzip, deflate

Accept-Language: en

HTTP/1.1 200 OK

Connection: Keep-Alive

Keep-Alive: timeout=5, max=100

x-powered-by: PHP/7.2.34

Content-Type: application/zip

Content-Disposition: attachment; filename=documents.zip

Content-Transfer-Encoding: binary

Expires: 0

Cache-Control: must-revalidate, post-check=0, pre-check=0

Pragma: public

Transfer-Encoding: chunked

Server: LiteSpeed

Strict-Transport-Security: max-age=3072000; includeSubdomains

X-Frame-Options: SAMEORIGIN

X-Content-Type-Options: nosniff

1 content packet, 148 server packets, 1 tunnel.

Entire conversation (199KB)

Show data as ASCII

Stream 73

Find Next

Filter Out This Stream

Print

Save as...

Back

Close

Burada 3 sorunun cevabı var. Dosyayı indirmeden zip dosyasının içindeki dosyanın adını soruyor. Bir diğer soru indirilen zip dosyasının indirildiği ipnin bağlı olduğu webserver bilgisini sormuş. Son soru da bulduğumuz webserver'ın sürümünü soruyor.

Zip dosyasını bulduğumuz pakete follow tcp stream yaparak detaylarını görüp soruların cevaplarına ulaşabiliriz.

Question Hint

Check HTTPS traffic. Narrow down the timeframe from 16:45:11 to 16:45:30.

✔ Correct Answer

What is the name of the webserver of the malicious IP from which the zip file was downloaded?

LiteSpeed

✔ Correct Answer

What is the version of the webserver from the previous question?

PHP/7.2.34

✔ Correct Answer

Malicious files were downloaded to the victim host from multiple domains. What were the three domains involved with this activity?

finejewels.com.au, thierbiagt.com, new.americoold.com

✔ Correct Answer

Wireshark - Filter Manager

dns&&frame.time >= "2021-09-24 16:45:11" && frame.time <= "2021-09-24 16:45:30"

No.	Time	Source	Destination	Protocol	Length	Info
2422	2021-09-24 16:45:11.440580	10.9.23.102	10.9.23.102	DNS	77	Standard query 6x0405 A finejewels.com.au
2423	2021-09-24 16:45:11.440883	10.9.23.102	10.9.23.102	DNS	93	Standard query response 6x0405 A finejewels.com.au A 148.72.192.206
2612	2021-09-24 16:45:19.933650	10.9.23.102	10.9.23.102	DNS	89	Standard query 6x73e8 A self-events.data.microsoft.com
2613	2021-09-24 16:45:19.933650	10.9.23.102	10.9.23.102	DNS	212	Standard query response 6x73e8 A self-events.data.microsoft.com CNAME self-events-dat
2877	2021-09-24 16:45:29.262640	10.9.23.102	10.9.23.102	DNS	128	Standard query 6x08ce SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.goingf
2878	2021-09-24 16:45:29.262640	10.9.23.102	10.9.23.102	DNS	198	Standard query response 6x08ce SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.goingf
2983	2021-09-24 16:45:29.487123	10.9.23.102	10.9.23.102	DNS	74	Standard query 6x0824 A thierbiagt.com
2984	2021-09-24 16:45:29.487123	10.9.23.102	10.9.23.102	DNS	90	Standard query response 6x0824 A thierbiagt.com A 210.245.99.247
3224	2021-09-24 16:45:25.457593	10.9.23.102	10.9.23.102	DNS	77	Standard query 6x05b4 A new.americoold.com
3225	2021-09-24 16:45:25.457593	10.9.23.102	10.9.23.102	DNS	93	Standard query response 6x05b4 A new.americoold.com A 148.72.53.144

Frame 2422: 77 bytes on wire (616 bits), 77 bytes captured (616 bits) on interface 0
Ethernet II, Src: RealtekU1c:47:aa (08:00:02:1c:47:aa), Dst: Dell_c2:09:6a (a4:1f:72:c2:09:6a)
Internet Protocol Version 4, Src: 10.9.23.102, Dst: 10.9.23.102
User Datagram Protocol, Src Port: 50761, Dst Port: 53
Domain Name System (query)

Soru şu kötü amaçlı dosyaların birden çok domainden indirildiğini söylüyor ve bizden bu domainleri bulmamızı istiyor.

Burada şahsen zorlandım, sitenin verdiği hint sayesinde dns olarak verilen zamanda filtreleyip domainleri buldum.

✔ Correct Answer

What is the version of the webserver from the previous question?

PHP/7.2.34

✔ Correct Answer

Malicious files were downloaded to the victim host from multiple domains. What were the three domains involved with this activity?

finejewels.com.au, thierbiagt.com, new.americoold.com

✔ Correct Answer

Which certificate authority issued the SSL certificate to the first domain from the previous question?

Answer format: *****

Check

What are the two IP addresses of the Cobalt Strike servers? Use

Wireshark - Follow TCP Stream (tcp.stream eq 90) - carnegie.pcap

tcp.stream eq 90

No.	Time	Source	Destination	Protocol	Length	Info
2424	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	77	Standard query 6x0405 A finejewels.com.au
2425	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	93	Standard query response 6x0405 A finejewels.com.au A 148.72.192.206
2426	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	89	Standard query 6x73e8 A self-events.data.microsoft.com
2427	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	212	Standard query response 6x73e8 A self-events.data.microsoft.com CNAME self-events-dat
2428	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	128	Standard query 6x08ce SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.goingf
2429	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	198	Standard query response 6x08ce SRV _ldap._tcp.Default-First-Site-Name._sites.dc._msdcs.goingf
2430	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	74	Standard query 6x0824 A thierbiagt.com
2431	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	90	Standard query response 6x0824 A thierbiagt.com A 210.245.99.247
2432	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	77	Standard query 6x05b4 A new.americoold.com
2433	2021-09-24 16:45:11.441505	10.9.23.102	10.9.23.102	DNS	93	Standard query response 6x05b4 A new.americoold.com A 148.72.53.144

Frame 2427: 247 bytes on wire (1976 bits), 247 bytes captured (1976 bits) on interface 0
Encapsulation type: Ethernet (1)
Arrival Time: Sep 24, 2021 16:45:11.8
Time shift for this packet: 0.0000000
Epoch Time: 1632561911.840716099 sec
Time delta from previous captured frame: 0.0000000
Time delta from previous displayed frame: 0.0000000
Frame Number: 2427
Frame Length: 247 bytes (1976 bits)
Capture Length: 247 bytes (1976 bits)

Bize bir önceki sorudaki ilk domainin SSL sertifikasını veren bulmamızı istiyor.

Follow tcp stream yaparak rahatça bulabiliyoruz.

Kritik soru: kurban makinenin bağlandığı cobalt strike sunucularının ip adresleri.

Bunu bulmanın birkaç yolu var. Direkt olarak pat diye şunu yaparsan bulursun gibi bir şey yok tamamen düşünce, ilerleyiş ve sorgulayış sonucu bulunur.

Cobalt strike beaconları genellikle 80,443,8080,8443 portlarını kullanır.

Address A	Port A	Address B	Port B	Packets	Bytes	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Rel Start	Duration	Bits/s A → B	Bits/s B
10.9.23.102	63622	185.106.96.158	80	11	1433	6	851	5	582	1105.262687	0.6470	10k	
10.9.23.102	63623	185.106.96.158	80	11	1433	6	851	5	582	1109.482106	0.6262	10k	
10.9.23.102	63624	185.106.96.158	80	9	1325	5	797	4	528	1114.355674	0.4920	12k	
10.9.23.102	63627	185.106.96.158	80	10	1379	6	851	4	528	1119.121735	3.7310	1824	
10.9.23.102	63458	185.125.204.174	443	30	10k	14	1588	16	8798	721.094411	1.0331	12k	
10.9.23.102	63481	185.125.204.174	443	27	10k	12	1444	15	8702	755.856147	1.8833	6133	
10.9.23.102	63508	185.125.204.174	443	24	8285	12	1470	12	6815	799.936728	0.8554	13k	
10.9.23.102	63541	185.125.204.174	443	25	8421	12	1446	13	6975	832.010664	1.8552	6235	
10.9.23.102	63543	185.125.204.174	443	20	4918	11	1294	9	3624	833.871832	0.8481	12k	
10.9.23.102	63410	185.125.204.174	8080	255	235k	81	5023	174	230k	581.342835	3.7323	10k	
10.9.23.102	63413	185.125.204.174	8080	29	10k	13	1539	16	8734	585.265235	1.0495	11k	
10.9.23.102	63423	185.125.204.174	8080	27	8501	14	1547	13	6954	614.911448	0.8403	14k	
10.9.23.102	63438	185.125.204.174	8080	23	8236	10	1367	13	6869	645.707867	0.8662	12k	
10.9.23.102	63445	185.125.204.174	8080	25	8372	12	1439	13	6933	682.303966	0.8596	13k	
10.9.23.102	63449	185.125.204.174	8080	23	8641	10	1367	13	7274	688.178814	0.8640	12k	
10.9.23.102	63450	185.125.204.174	8080	24	8195	11	1356	13	6839	689.049700	0.8522	12k	
10.9.23.102	63451	185.125.204.174	8080	24	8318	11	1385	13	6933	694.913733	0.8581	12k	
10.9.23.102	63452	185.125.204.174	8080	23	8236	10	1367	13	6869	700.790160	0.8396	13k	
10.9.23.102	63453	185.125.204.174	8080	34	13k	17	6383	17	7022	701.641048	0.8830	57k	
10.9.23.102	63455	185.125.204.174	8080	24	8296	11	1385	13	6911	707.538603	0.8857	12k	
10.9.23.102	63456	185.125.204.174	8080	26	8440	13	1529	13	6911	713.429501	0.9000	13k	
10.9.23.102	63457	185.125.204.174	8080	389	383k	112	6839	277	376k	719.335390	1.7260	31k	
10.9.23.102	63459	185.125.204.174	8080	23	8342	10	1367	13	6975	726.070932	0.8582	12k	
10.9.23.102	63462	185.125.204.174	8080	25	8436	12	1439	13	6997	731.931522	0.8496	13k	
10.9.23.102	63463	185.125.204.174	8080	25	8344	12	1475	13	6869	737.790140	0.8543	13k	
10.9.23.102	63465	185.125.204.174	8080	1375	1387k	408	22k	967	1364k	743.649672	4.2193	43k	
10.9.23.102	63468	185.125.204.174	8080	28	9042	14	2173	14	6869	749.039324	0.8635	20k	
10.9.23.102	63480	185.125.204.174	8080	22	8246	10	1367	12	6879	754.913890	1.5942	6859	
10.9.23.102	63483	185.125.204.174	8080	27	8707	14	1860	13	6847	756.509509	1.3956	10k	

Conversations kısmında destination portları veya adresleri sıralayarak bulma ihtimalimiz hızlanır. Şüphelendiğimiz adresleri virus total içerisinde sorgulamamız gereklidir, aslında soru bizden direkt bunu yapmamızı istiyor. Bir diğer yol ise tcp threeway handshake paketlerini incelemek.

Security vendors' analysis	Do you want to automate checks?		
Abuse	Clean	Actonix	Clean
ADMINUSLabs	Clean	AlI Labs (MONITORAPP)	Clean
AlienVault	Clean	alphaMountain.ai	Clean
Antiy-AVL	Clean	benkow.cc	Clean
BitDefender	Clean	Bkav	Clean
Cortego	Clean	CMS Army	Clean
CMC Threat Intelligence	Clean	CDF	Clean
Criminal IP	Clean	Cyble	Clean
CyKadar	Clean	desenmascara.me	Clean
DNS	Clean	DrWeb	Clean

drb_ra 4 years ago

Cobalt Strike Server Found
C2: HTTPS @ 185[.]125[.]204[.]174:4444
C2 Server: securitybusinpu[.]com[.]query-3[.]3[.]1[.]1[.]min[.]js,185[.]125[.]204[.]174[.]query-3[.]3[.]1[.]1[.]min[.]js
POST URI: /query-3[.]3[.]2[.]min[.]js
Country: N/A
ASN: Hydra Communications Ltd
#c2 #cobaltstrike

drb_ra 4 years ago

Cobalt Strike Server Found
C2: HTTPS @ 185[.]125[.]204[.]174:8080
C2 Server: securitybusinpu[.]com[.]query-3[.]3[.]1[.]1[.]min[.]js,185[.]125[.]204[.]174[.]query-3[.]3[.]1[.]1[.]min[.]js
POST URI: /query-3[.]3[.]2[.]min[.]js
Country: N/A
ASN: N/A
#c2 #cobaltstrike

You must be signed in to post a comment.

**drb_ra**
4 years ago

Cobalt Strike Server Found
C2: HTTPS @ 185[.]106[.]96[.]158:8888
C2 Server: survmeter[.]live[.]gscpl[.]R[.]185[.]106[.]96[.]158[.]gscpl[.]R[.]
POST URL: /supprq/sa/
Country: United States
ASN: DediPath
Host Header: ocspl[.]verisign[.]com
#C2 #cobaltstrike

**drb_ra**
4 years ago

Cobalt Strike Server Found
C2: HTTPS @ 185[.]106[.]96[.]158:443
C2 Server: survmeter[.]live[.]gscpl[.]R[.]185[.]106[.]96[.]158[.]gscpl[.]R[.]
POST URL: /supprq/sa/
Country: United States
ASN: DediPath
Host Header: ocspl[.]verisign[.]com
#C2 #cobaltstrike

**drb_ra**
4 years ago

Cobalt Strike Server Found
C2: HTTP @ 185[.]106[.]96[.]158:80
C2 Server: survmeter[.]live[.]gscpl[.]R[.]185[.]106[.]96[.]158[.]gscpl[.]R[.]
POST URL: /supprq/sa/
Country: N/A
ASN: N/A
Host Header: ocspl[.]verisign[.]com
#C2 #cobaltstrike

185.106.96.158

Did you intend to search across the file corpus instead? [Click here](#)

3 / 94

Community Score

3/94 security vendors flagged this IP address as malicious

185.106.96.158 (185.106.96.0/24)

AS 133619 (DESVPS)

US

Last Analysis Date
13 days ago

DETECTION

DETAILS

RELATIONS

COMMUNITY

[Join our Community](#) and enjoy additional community insights and crowdsourced detections, plus an API key to [automate checks](#).

Security vendors' analysis

Do you want to automate checks?

ADMINUSLabs	Malicious	alphaMountain.ai	Malicious
Kaspersky	Malware	Abusix	Clean
Acronis	Clean	AllLabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean
benkow.cc	Clean	BitDefender	Clean

Which certificate authority issued the SSL certificate to the first domain from the previous question?

GoDaddy

✓ Correct Answer

What are the two IP addresses of the Cobalt Strike servers? Use VirusTotal (the Community tab) to confirm if IPs are identified as Cobalt Strike C2 servers. (answer format: enter the IP addresses in sequential order)

185.106.96.158, 185.125.204.174

✓ Correct Answer

What is the Host header for the first Cobalt Strike IP address from the previous question?

ocspl.verisign.com

✓ Correct Answer

What is the domain name for the first IP address of the Cobalt Strike server? You may use VirusTotal to confirm if it's the Cobalt Strike server (check the Community tab).

Answer format: *****

Check

Analysis - File Manager

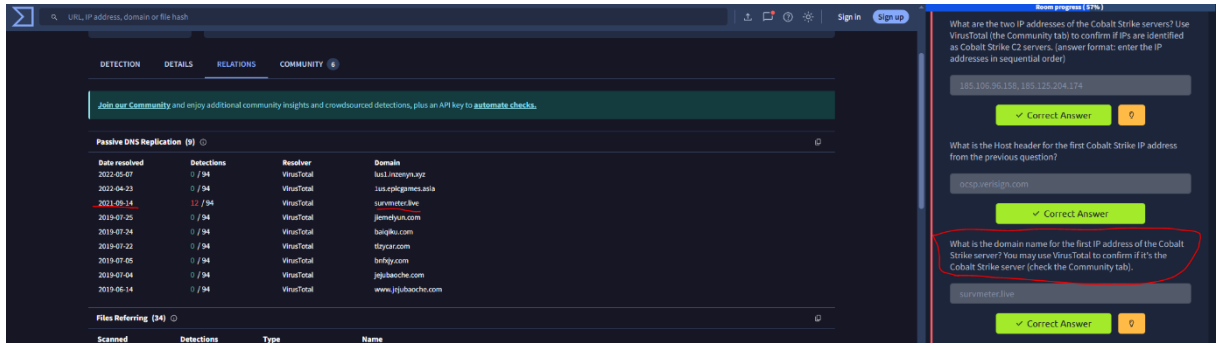
Ethernet - 8	IPv4 - 109	IPv6	TCP - 447
Address A	Port A	Address B	Port
10.9.23.102	63489	2.20.156.175	
10.9.23.102	63361	2.20.205.205	
10.9.23.102	49668	10.9.23.5	
10.9.23.102	49671	10.9.23.5	
10.9.23.102	49673	10.9.23.5	
10.9.23.102	49674	10.9.23.5	
10.9.23.102	49675	10.9.23.5	
10.9.23.102	49676	10.9.23.5	
10.9.23.102	49677	10.9.23.5	
10.9.23.102	49678	10.9.23.5	
10.9.23.102	49679	10.9.23.5	
10.9.23.102	49680	10.9.23.5	
10.9.23.102	49681	10.9.23.5	
10.9.23.102	49682	10.9.23.5	
10.9.23.102	49683	10.9.23.5	
10.9.23.102	49684	10.9.23.5	
10.9.23.102	49685	10.9.23.5	
10.9.23.102	49686	10.9.23.5	
10.9.23.102	49687	10.9.23.5	
10.9.23.102	49688	10.9.23.5	
10.9.23.102	49689	10.9.23.5	
10.9.23.102	49690	10.9.23.5	
10.9.23.102	49691	10.9.23.5	
10.9.23.102	49692	10.9.23.5	
10.9.23.102	49693	10.9.23.5	
10.9.23.102	49694	10.9.23.5	
10.9.23.102	49695	10.9.23.5	
10.9.23.102	49696	10.9.23.5	
10.9.23.102	49697	10.9.23.5	
10.9.23.102	49698	10.9.23.5	
10.9.23.102	49699	10.9.23.5	

Wireshark - Follow TCP Stream (tcp.stream eq 298) - carnage.pcap

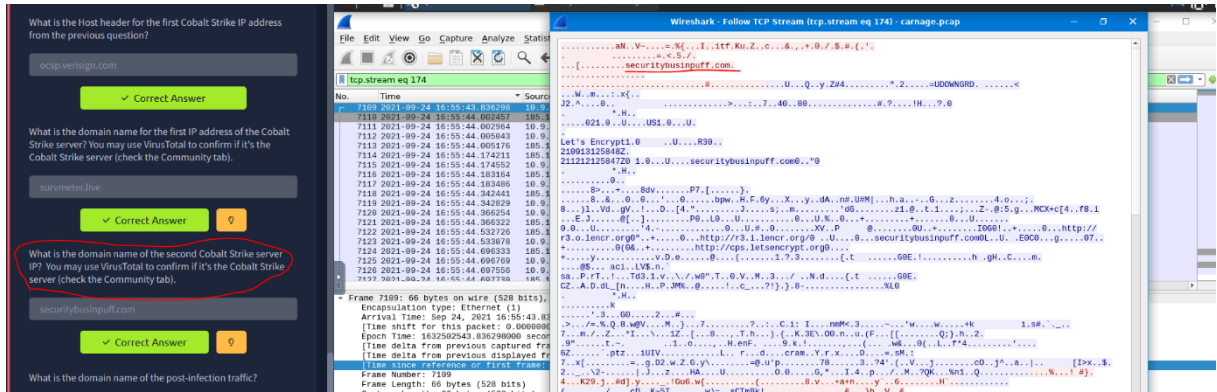
GET /gscpl.R/
oapipmcnigpfpfmgahdbbbhigcwfgekpidlacgedhacnagdehdcaajhknogbipjbmieebdchniabihjlbgrpabaekcehfmaidjohbapodi
gfploepohfddhndimgalhehiamfjocnaloajjpalhepocnckgknilliedlherfghndlowjohfaiiaccdeibenhogagfkafrfkccpjegntion
ajbnapffiamjnhedpochmiclog HTTP/1.1
Accept: */*
Host: ocspl.verisign.com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/92.0.4515.131
Safari/537.36 (990/78.0.4093.147
Connection: Keep-Alive
Cache-Control: no-cache

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 17:00:19 GMT
Server: Apache/2.4.18 (Ubuntu)
Content-Length: 0
Keep-Alive: timeout=20, max=200
Connection: keep-alive
Content-Type: application/ocsp-response
content-transfer-encoding: binary
Cache-Control: max-age=288451, public, no-transform, must-revalidate

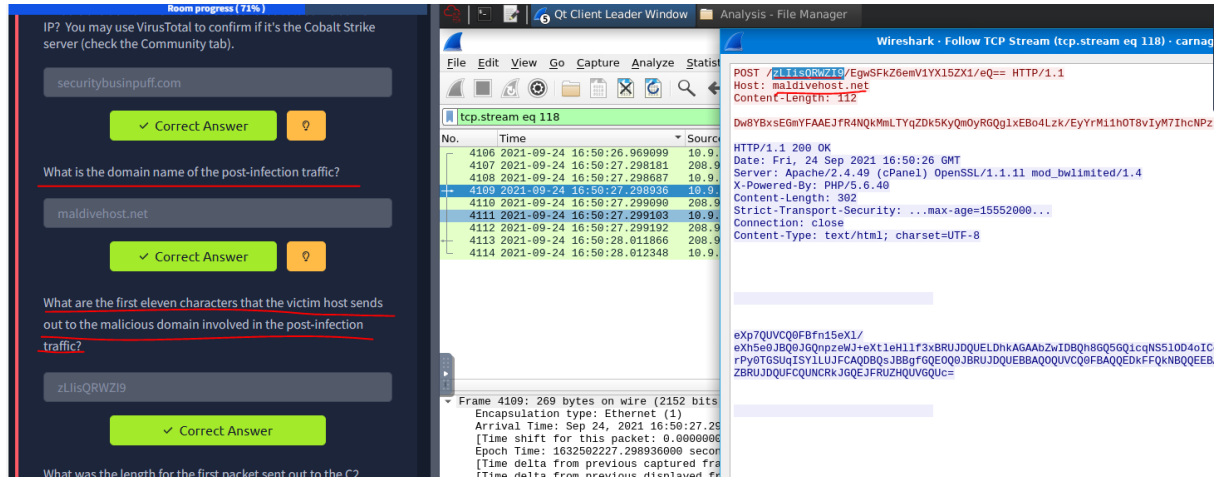
İlk cobalt strike sunucusundaki sunucu header bilgisini sormuş. C2 sunucusuna tcp stream followladığımız zaman bu bilgiyi rahatça görebiliriz.



İlk cobalt strike sunucusundaki domain adını sormuş. Virus total içersinden relations sayfasından bu sorunun cevabını bulabiliyoruz.



Aynı soru ama bu sefer 2. Adrese sorulmuş. Virustotal kullanmak yerine, kullandığım başka bir alternatif metodu göstermek istedim. ip.addr == 185.125.204.174 & tcp.port == 443 parametreleri ile x ipinde tcp bağlantısı kurmuş olan paketleri listelemesini istedim. Follow tcp stream dediğim zaman domain adını bulabildim.



Ekrandaki altı çizili ilk soruda post infection domain adını sormuş. Kısaca post infection tanımı: sisteme sızıldıktan ve c2 sunucusuna bağlandıktan sonra yapılan her iletişime post infection communication denir. Komut almak, kalıcılık sağlamak, dosya göndermek gibi. Şimdi düz mantık saldırgan genellikle kurban makineye veri göndereceği için bizim POST olarak filtreleme yapmamız gereklidir. Kullandığım parametreler http.request.method == POST. Yine aynı şekilde doğru paketi bulduğumuzda soruların cevabını rahatlıkla buluyoruz.

maldiverhacker

✓ Correct Answer

What are the first eleven characters that the victim host sends out to the malicious domain involved in the post-infection traffic?

zLisQRWZi9

✓ Correct Answer

What was the length for the first packet sent out to the C2 server?

281

✓ Correct Answer

What was the Server header for the malicious domain from the previous question?

Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

✓ Correct Answer

File Edit View Go Capture Analyze Statistics

tcp.stream eq 104

No. Time Source

3807 2021-09-24 16:46:16.141471 10.9.23.102 10.9.23.5

3820 2021-09-24 16:46:16.393519 208.9.23.102 10.9.23.5

3821 2021-09-24 16:46:16.394002 10.9.23.102 10.9.23.5

3822 2021-09-24 16:46:16.395000 10.9.23.102 10.9.23.5

3823 2021-09-24 16:46:16.395181 10.9.23.102 10.9.23.5

3824 2021-09-24 16:46:16.395199 208.9.23.102 10.9.23.5

3825 2021-09-24 16:46:16.395345 208.9.23.102 10.9.23.5

3851 2021-09-24 16:46:17.143575 208.9.23.102 10.9.23.5

3852 2021-09-24 16:46:17.149961 208.9.23.102 10.9.23.5

3853 2021-09-24 16:46:17.150137 10.9.23.102 10.9.23.5

POST /zLiisQRWZi9/OQsaD1xzHTgtfjMcGypGenpIdWF5eW9f3k= HTTP/1.1
Host: maldiverhacker.net
Content-Length: 112

Dw8YBxsEGnYFAAE3fR4NqkMmLTyqZDK5KyQm0yRGQglxEBo4Lzk/EyYrM1h0T8vIyM7Ih

HTTP/1.1 200 OK
Date: Fri, 24 Sep 2021 16:46:15 GMT
Server: Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4
X-Powered-By: PHP/5.6.40
Content-Length: 382
Strict-Transport-Security: ...max-age=15552000...
Connection: close
Content-Type: text/html; charset=UTF-8

eXp7QUVCQ9FBfn15eX1/
enNekJBQ0JGQnpzeWJ+eXtleH11f3xBRUJQQUeLdHkAGAAzWzIDBQh8Q5GQicqNS5100
rPy0T6SuqISY1LUJfCAQDBQs3BBgF0QE0QJBRUJQQUEBBAQ0UVCQ9fBAQ0EKFfQkNBQ
ZBRUJQFQCUNCRkQJGf3FRUzHUVCQ9fBAQ0EKFfQkNBQ

C2 sunucusuna gönderilen paketin uzunluğu ve domaini soruyor.

What was the Server header for the malicious domain from the previous question?

Apache/2.4.49 (cPanel) OpenSSL/1.1.1l mod_bwlimited/1.4

✓ Correct Answer

The malware used an API to check for the IP address of the victim's machine. What was the date and time when the DNS query for the IP check domain occurred? (answer format: yyyy-mm-dd hh:mm:ss UTC)

2021-09-24 17:00:04

✓ Correct Answer

What was the domain in the DNS query from the previous question?

api.ipify.org

✓ Correct Answer

Looks like there was some malicious spam (malspam) activity going on. What was the first MAIL FROM address observed in the traffic?

Answer format: *****

ip.addr == 10.9.23.102 && dns && frame contains "api"

No. Time Source Destination Protocol Length Info

990 2021-09-24 16:44:22.274695 10.9.23.102 10.9.23.5 DNS 71 Standard query 0x26b2 A api.msn.com

993 2021-09-24 16:44:22.419852 10.9.23.5 10.9.23.102 DNS 186 Standard query response 0x26b2 A api.msn.com CNAME api.msn.com a-0083.a-sedge

24147 2021-09-24 17:00:04.053554 10.9.23.102 10.9.23.5 DNS 73 Standard query 0xc02c A api.ipify.org

25279 2021-09-24 17:00:59.174809 10.9.23.102 10.9.23.5 DNS 73 Standard query 0x8eed A api.ipify.org

25281 2021-09-24 17:00:59.244491 10.9.23.5 10.9.23.102 DNS 299 Standard query response 0x8eed A api.ipify.org CNAME nagano-19599.herokuapp.com

26756 2021-09-24 17:02:17.477261 10.9.23.102 10.9.23.5 DNS 73 Standard query 0x8097 A api.ipify.org

26763 2021-09-24 17:02:17.634232 10.9.23.5 10.9.23.102 DNS 299 Standard query response 0x8097 A api.ipify.org CNAME nagano-19599.herokuapp.com

27836 2021-09-24 17:02:35.839640 10.9.23.102 10.9.23.5 DNS 73 Standard query 0x5258 A api.ipify.org

27838 2021-09-24 17:02:35.995593 10.9.23.5 10.9.23.102 DNS 299 Standard query response 0x5258 A api.ipify.org CNAME nagano-19599.herokuapp.com

Arrival Time: Sep 24, 2021 17:00:54.233864800 UTC
[Time shift for this packet: 0.00000000 seconds]
Epoch Time: 1632562804.233864800 seconds
[Time delta from previous captured frame: 0.002061000 seconds]
[Time delta from previous displayed frame: 0.140510000 seconds]
[Time since reference or first frame: 981.40197000 seconds]
Frame Number: 24140
Frame Length: 299 bytes (2392 bits)
Capture Length: 299 bytes (2392 bits)
[Frame is marked: False]
[Frame is ignored: False]

0000 00 08 02 1c 47 ae 04 1f 72 c2 09 0a 08 00 45 000...f...j...E...
0010 01 1d 42 b0 06 00 00 11 b4 96 0a 09 17 05 0a 09B.....
0020 17 66 00 35 ee 74 01 09 aa 14 c9 2c 81 80 00 01F.S.t.....
0030 00 0a 00 00 00 00 03 01 79 00 00 00 78 66 78a...ipify...
0040 03 0f 72 67 00 00 01 00 01 c9 0c 08 05 08 01 00org.....
0050 00 00 c8 00 1c 0c 6e 01 67 01 0e 0f 20 31 39 35na gano-195...
0060 39 39 00 00 05 72 6f 00 75 73 73 6c 03 03 0f 6d 99-herok...
0070 00 c9 2b 00 05 00 01 00 00 0c 0c 09 2e 13 65 6cel

Saldırganın kurban makinenin ip adresini kontrol etmek için bir API kullandığını söylüyor. Bunun için yapılan dns sorgusunun ne zaman olduğunu sormuş.

Bunu bulmak için tam olarak doğru bir yol izledim mi emin değilim ama benim işimi gördü.

ip addr == ip && dns && frame contains "api"

Frame contains kısmına api yazdığımızdan dolayı bunu bulmak daha kolay oldu.

✓ Correct Answer

The malware used an API to check for the IP address of the victim's machine. What was the date and time when the DNS query for the IP check domain occurred? (answer format: yyyy-mm-dd hh:mm:ss UTC)

2021-09-24 17:00:04

✓ Correct Answer

What was the domain in the DNS query from the previous question?

api.ipify.org

✓ Correct Answer

Looks like there was some malicious spam (malspam) activity going on. What was the first MAIL FROM address observed in the traffic?

Answer format: *****

laptop contains "FROM"

No. Time Source Destination Protocol Length Info

28878 2021-09-24 17:02:48.778817 10.9.23.102 185.4.28.138 SMTP 66 C: MAIL FROM: <FARUK@BENLILA.COM>

28886 2021-09-24 17:02:49.219202 10.9.23.102 185.4.28.138 SMTP 67 C: MAIL FROM: <FARUK@BENLILA.COM>

48434 2021-09-24 17:03:59.536309 10.9.23.102 93.09.228.08 SMTP 95 C: MAIL FROM: <info@everdinkaliye.com>

67562 2021-09-24 17:04:49.704201 10.9.23.102 185.14.56.246 SMTP 261 C: MAIL FROM: <roses@baccarado.com> BODY=88111111

En aşağıdaki soruda mails spam olduğunu söylüyor. İlk MAIL FROM paketinin kimden geldiğini soruyor.

Mail olduğu için direkt olarak smtp filtreleyebiliriz. Contains FROM yazarsak sonuçlar dahada daralacaktır.

The malware used an API to check for the IP address of the victim's machine. What was the date and time when the DNS query for the IP check domain occurred? (answer format: yyyy-mm-dd hh:mm:ss UTC)

2021-09-24 17:00:04

✓ Correct Answer

What was the domain in the DNS query from the previous question?

api.jilly.org

✓ Correct Answer

Looks like there was some malicious spam (malspam) activity going on. What was the first MAIL FROM address observed in the traffic?

farshin@mailfa.com

✓ Correct Answer

How many packets were observed for the SMTP traffic?

Answer format: ****

Check

smtp

No.	Time	Source	Destination	Protocol	Length	Info
28576	2021-09-24 17:02:46.778617	185.4.29.135	185.4.29.135	SMTP	86	C: MAIL FROM<farshin@mailfa.com>
28578	2021-09-24 17:02:46.778159	185.4.29.135	185.4.29.135	SMTP	66	C: AUTH LOGIN
28598	2021-09-24 17:02:47.009894	185.4.29.135	185.4.29.135	SMTP	72	S: 334 VXNlcnQ5bm9keQ==
28662	2021-09-24 17:02:47.033111	185.4.29.135	185.4.29.135	SMTP	151	S: 550 Your SMTP Service is disable please check by your mailservice provider.
28685	2021-09-24 17:02:47.617861	185.4.29.135	185.4.29.135	SMTP	92	C: User: a58zWtUlnNoYXpZmLAWFpGZHLnVUQ==
28685	2021-09-24 17:02:47.663031	52.97.201.242	185.4.29.135	SMTP	105	S: 220 ZMRP27RCAG181.outlook.office365.com Microsoft ESMTPL MAIL Service ready
28711	2021-09-24 17:02:47.848892	185.4.29.135	185.4.29.135	SMTP	72	S: 334 UGFzc29keQ==
28742	2021-09-24 17:02:48.252166	52.97.201.242	185.4.29.135	SMTP	70	C: EHLO localhost
28748	2021-09-24 17:02:48.363106	52.97.201.242	185.4.29.135	SMTP	165	S: 220 ZMRP27RCAG183.outlook.office365.com Microsoft ESMTPL MAIL Service ready
28781	2021-09-24 17:02:48.419170	52.97.201.242	185.4.29.135	SMTP	259	S: 250-ZMRP27RCAG181.outlook.office365.com Hello [173.66.46.112] SIZE 1572864
28783	2021-09-24 17:02:48.611926	185.4.29.135	185.4.29.135	SMTP	66	C: Pass: HYN20TfZjyKw
28776	2021-09-24 17:02:48.850366	185.4.29.135	185.4.29.135	SMTP	74	S: 235 authenticated.
28788	2021-09-24 17:02:48.861668	185.4.29.135	52.97.201.242	SMTP	64	C: STARTTLS
28782	2021-09-24 17:02:48.863176	185.4.29.135	52.97.201.242	SMTP	70	C: EHLO localhost
28798	2021-09-24 17:02:49.005138	52.97.201.242	185.4.29.135	SMTP	83	S: 220 2.0.0 SMTP server ready
28791	2021-09-24 17:02:49.005154	52.97.201.242	185.4.29.135	SMTP	259	S: 250-ZMRP27RCAG183.outlook.office365.com Hello [173.66.46.112] SIZE 1572864
28795	2021-09-24 17:02:49.049233	89.96.212.244	185.4.29.135	SMTP	94	S: 220 eFesto.unitecampus.it ESMTPL Postfix
28804	2021-09-24 17:02:49.111372	185.4.29.135	185.4.29.135	SMTP	83	C: MAIL FROM<nochain.sharif@mailfa.com>
28804	2021-09-24 17:02:49.111372	185.4.29.135	185.4.29.135	SMTP	70	C: MAIL FROM<nochain.sharif@mailfa.com>

Frame 28804: 93 bytes on wire (744 bits), 93 bytes captured (744 bits) on interface eth0

Encapsulation type: Ethernet (1)

Arrival Time: Sep 24, 2021 17:02:49.113920000 UTC

[Time shift for this packet: 0.000000000 seconds]

Epoch Time: 1632592969.113920000 seconds

[Time delta from previous captured frame: 0.000002000 seconds]

[Time delta from previous displayed frame: 0.664359000 seconds]

[Link layer is different or first frame: 1146.2170000 seconds]

Frame Number: 28804

Frame Length: 93 bytes (744 bits)

Capture Length: 93 bytes (744 bits)

0000 20 45 2a b6 93 f1 00 68 82 3c 4f ae 08 00 45 80G...E..

0010 00 4f 2f 58 40 00 80 66 d3 56 6a 89 17 66 09 04 -O/Xp...V...f..

0020 1d 87 f8 c6 00 19 00 ab 83 7b ba be 4b 37 56 18u..KPP

0030 fa 5b 8f 28 00 00 4d 41 49 4c 26 46 52 4f 40 3a *(-NA IL FROM: choklan.sharif@

0040 3e 58 6f 33 65 00 66 2a 73 68 61 72 68 66 69 40 choklan.sharif@

0050 6d 61 89 6c 66 61 2e 63 6f 6d 3e 68 0a mailfa.c omp=

Smtp trafiğinde ne kadar paket olduğunu soruyor. Direkt smtp filtrelyip görebiliriz.

Cephe 1: Hedef Seçimi ve Keşif (Recon Haritası)

Hedef olarak zypmedia.com adresini seçtim. Şirketin kendisinden izin aldım, şirket herhangi bir bug bounty programına dahil değil.

```
(kali@kali)-[~]
$ subfinder -d zypmedia.com -o subfinderoutput.txt

projectdiscovery.io

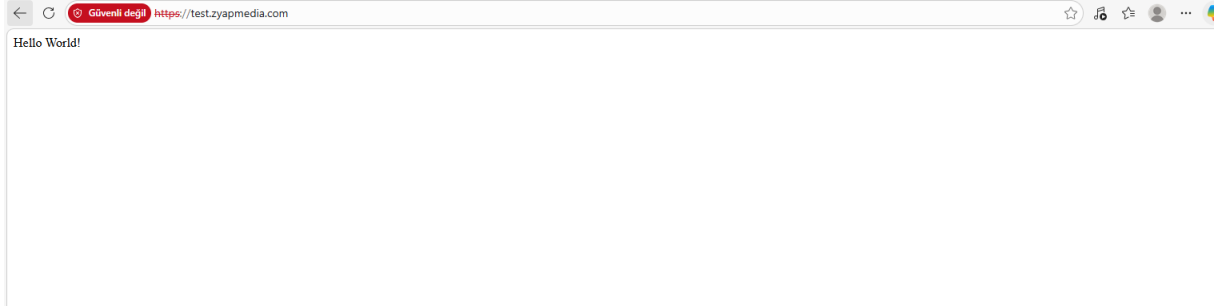
[INF] Current subfinder version v2.12.0 (latest)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for zypmedia.com
www.zypmedia.com
thieveryonline.zypmedia.com
www.thieveryonline.zypmedia.com
test.zypmedia.com
www.test.zypmedia.com
[INF] Found 5 subdomains for zypmedia.com in 577 milliseconds 54 microseconds
```

Recon

Öncelikle subfinder ile subdomain enumeration işlemime başladım (bilgi toplama).

5 tane subdomain buldum sadece 2 tanesi canlıydı test.zyapmedia.com ve zyapmedia.com

Test adı ile başlayan adresin açık unutulup bırakıldığını düşündüm içeride unutulmuş bir şeyler olabileceği için ilk bu adresi incelemeye başladım.



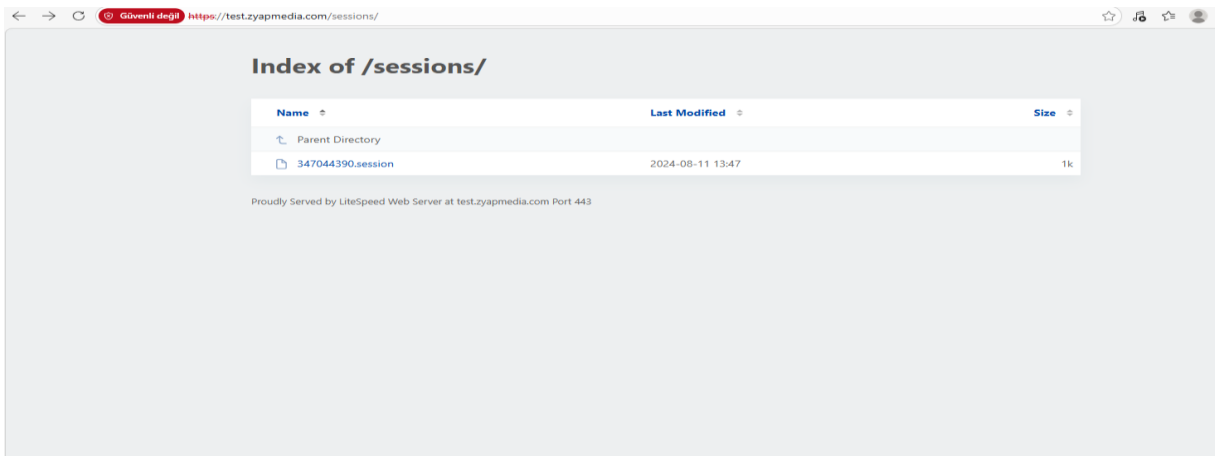
Bomboş bir sayfa tam olarak bir test sayfası, sadece hello world yazıyor.

```
[03:10:11] 301 - 795B - /~sysadm → https://test.zyapmedia.com/~sysadm/
[03:10:11] 301 - 795B - /~test → https://test.zyapmedia.com/~test/
[03:10:11] 301 - 795B - /~sysadmin → https://test.zyapmedia.com/~sysadmin/
[03:10:11] 301 - 795B - /~user → https://test.zyapmedia.com/~user/
[03:10:11] 301 - 795B - /~tmp → https://test.zyapmedia.com/~tmp/
[03:10:11] 301 - 795B - /~webmaster → https://test.zyapmedia.com/~webmaster/
[03:10:12] 301 - 795B - /~www → https://test.zyapmedia.com/~www/
[03:10:16] 301 - 795B - /bandwidth → https://test.zyapmedia.com/bandwidth/
[03:10:18] 301 - 795B - /cgi-bin → https://test.zyapmedia.com/cgi-bin/
[03:10:18] 403 - 1KB - /cgi-bin/
[03:10:19] 301 - 795B - /cgi-sys → https://test.zyapmedia.com/cgi-sys/
[03:10:21] 301 - 0B - /controlpanel → https://server174.web-hosting.com:2083
[03:10:21] 301 - 0B - /cpanel → https://server174.web-hosting.com:2083
[03:10:25] 403 - 1KB - /error_log
[03:10:34] 301 - 795B - /java-sys → https://test.zyapmedia.com/java-sys/
[03:10:38] 301 - 795B - /mailman → https://test.zyapmedia.com/mailman/
[03:10:46] 301 - 795B - /pipermail → https://test.zyapmedia.com/pipermail/
[03:10:55] 403 - 93B - /server-status
[03:10:56] 301 - 795B - /sessions → https://test.zyapmedia.com/sessions/
[03:11:11] 301 - 0B - /webmail → https://server174.web-hosting.com:2096
```

Task Completed

```
(kali@kali)-[~]
$
```

Directory enumeration işlemine başladım. Dirsearch durum kodları yanlış olsa daönümebirkaç tane işe yarayabilecek izin verdi.



Sessions yani oturumlar dizini açık ffuf ile üstüne gittim ama daha sonuç alamadım. İçeride bir sessions dosyası var hemen indirdim.

```
347044390 (1) - Not Defteri
Dosya Düzen Biçim Görünüm Yardım
{"session_id":347044390,"corresponding_user":42}
```

Maalesef başka bir session bilgisi veya bu session id üzerinden kullanabileceğim bir şey bulamadım. Kısaca risklerini gösterelim

Olası riskler:

kullanıcı oturumlarının ele geçirilmesi, kullanıcı ID bilgilerinin sızması, yetkisiz erişim, hesap ele geçirme. (IDOR ve Session Hijacking ağırlıklı) Tabiki bunlar kesinlikle var diye bir şey yok bunlar sadece olası riskler.

```
www.thieveryonline.zyapmedia.com
(kali@kali)-[~]
$ dirsearch -u https://test.zyapmedia.com -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -e php,asp,txt,zip,log,bak,old,json,xml,git,env -t 50 -x 403,404
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API
. See https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, asp, txt, zip, log, bak, old, json, xml, git, env | HTTP method: GET | Threads: 50
Wordlist size: 220545

Output File: /home/kali/reports/BATCH-26-03-09_03-08-59/BATCH.txt

Target: http://dirsearch/

[03:08:59] Starting:
There was a problem in the request to: http://dirsearch/

Target: https://test.zyapmedia.com/

[03:08:59] Starting:
[03:09:03] 301 - 795B - /cgi-bin -> https://test.zyapmedia.com/cgi-bin/
[03:09:05] 301 - 795B - /mailman -> https://test.zyapmedia.com/mailman/
[03:09:07] 301 - 795B - /pipemail -> https://test.zyapmedia.com/pipemail/
[03:09:11] 301 - 0B - /webmail -> https://server174.web-hosting.com:2096
[03:09:17] 301 - 795B - /sessions -> https://test.zyapmedia.com/sessions/
[03:09:31] 301 - 795B - /bandwidth -> https://test.zyapmedia.com/bandwidth/
[03:09:36] 301 - 795B - /cgi-sys -> https://test.zyapmedia.com/cgi-sys/
[03:09:48] 301 - 0B - /controlpanel -> https://server174.web-hosting.com:2083
[03:10:04] 301 - 0B - /cpanel -> https://server174.web-hosting.com:2083
[03:11:17] 301 - 795B - /%7Emike -> https://test.zyapmedia.com/~mike/
[03:13:11] 301 - 795B - /%7Ejeff -> https://test.zyapmedia.com/~jeff/
[03:15:56] 301 - 795B - /%7Er -> https://test.zyapmedia.com/~r/
[03:15:56] 301 - 795B - /%7E3 -> https://test.zyapmedia.com/~3/
[03:17:21] 301 - 795B - /%7Egreg -> https://test.zyapmedia.com/~greg/
[03:17:24] 301 - 795B - /%7Echris -> https://test.zyapmedia.com/~chris/
[03:17:24] 301 - 795B - /%7Ecook -> https://test.zyapmedia.com/~cook/
[03:17:25] 301 - 795B - /%7Ets -> https://test.zyapmedia.com/~ts/
[03:17:26] 301 - 795B - /%7Erachna -> https://test.zyapmedia.com/~rachna/
[03:17:28] 301 - 795B - /%7Eesr -> https://test.zyapmedia.com/~esr/
[03:17:30] 301 - 795B - /%7Emasmith -> https://test.zyapmedia.com/~masmith/
[03:17:31] 301 - 795B - /%7Edugsong -> https://test.zyapmedia.com/~dugsong/
[03:17:43] 301 - 795B - /%7Ecbdon -> https://test.zyapmedia.com/~cbdon/
```

Dirsearch sonrası dirb üzerinden de uzun bir tarama yaptım yine pek sonuç alamadım genellikle 403 ve 404 ile karşılaştım. Bunların üstüne ana domaine dönmeye karar verdim.

```
+ https://zyapmedia.com/alerts (CODE:503|SIZE:592)
+ https://zyapmedia.com/alias (CODE:503|SIZE:592)
+ https://zyapmedia.com/aliases (CODE:503|SIZE:592)
+ https://zyapmedia.com/all (CODE:503|SIZE:592)
+ https://zyapmedia.com/alltime (CODE:503|SIZE:592)
+ https://zyapmedia.com/all-wcprops (CODE:503|SIZE:592)
+ https://zyapmedia.com/alpha (CODE:503|SIZE:592)
+ https://zyapmedia.com/alumni (CODE:503|SIZE:592)
+ https://zyapmedia.com/alumni_add (CODE:503|SIZE:592)
+ https://zyapmedia.com/alumni_details (CODE:503|SIZE:592)
+ https://zyapmedia.com/alumni_info (CODE:503|SIZE:592)
+ https://zyapmedia.com/alumni_reunions (CODE:503|SIZE:592)
=> DIRECTORY: https://zyapmedia.com/bandwidth/
=> DIRECTORY: https://zyapmedia.com/cgi-bin/
+ https://zyapmedia.com/cgi-bin/ (CODE:403|SIZE:1242)
=> DIRECTORY: https://zyapmedia.com/cgi-sys/
+ https://zyapmedia.com/controlpanel (CODE:301|SIZE:0)
+ https://zyapmedia.com/cpanel (CODE:301|SIZE:0)
=> DIRECTORY: https://zyapmedia.com/dev/
=> DIRECTORY: https://zyapmedia.com/games/
=> DIRECTORY: https://zyapmedia.com/images/
=> DIRECTORY: https://zyapmedia.com/inc/
+ https://zyapmedia.com/index.html (CODE:200|SIZE:28276)
=> DIRECTORY: https://zyapmedia.com/java-sys/
=> DIRECTORY: https://zyapmedia.com/layout/
=> DIRECTORY: https://zyapmedia.com/mailman/
=> DIRECTORY: https://zyapmedia.com/oldsite/
=> DIRECTORY: https://zyapmedia.com/pipermail/
=> DIRECTORY: https://zyapmedia.com/posts/
=> DIRECTORY: https://zyapmedia.com/redesign/
=> DIRECTORY: https://zyapmedia.com/servers/
+ https://zyapmedia.com/webmail (CODE:301|SIZE:0)

—— Entering directory: https://zyapmedia.com/~http/ ——
+ https://zyapmedia.com/~http/.svn (CODE:403|SIZE:1242)

—— Entering directory: https://zyapmedia.com/~root/ ——
+ https://zyapmedia.com/~root/.svn (CODE:403|SIZE:1242)

—— Entering directory: https://zyapmedia.com/~user/ ——
+ https://zyapmedia.com/~user/.svn (CODE:403|SIZE:1242)

—— Entering directory: https://zyapmedia.com/bandwidth/ ——
+ https://zyapmedia.com/bandwidth/.svn (CODE:403|SIZE:1242)

—— Entering directory: https://zyapmedia.com/cgi-bin/ ——
+ https://zyapmedia.com/cgi-bin/.svn (CODE:403|SIZE:1242)

—— Entering directory: https://zyapmedia.com/cgi-sys/ ——
+ https://zyapmedia.com/cgi-sys/.svn (CODE:403|SIZE:1242)
+ https://zyapmedia.com/cgi-sys/index.html (CODE:500|SIZE:73)
```



```
[kali@kali:~]$ dirb https://test.zyapmedia.com/ -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt

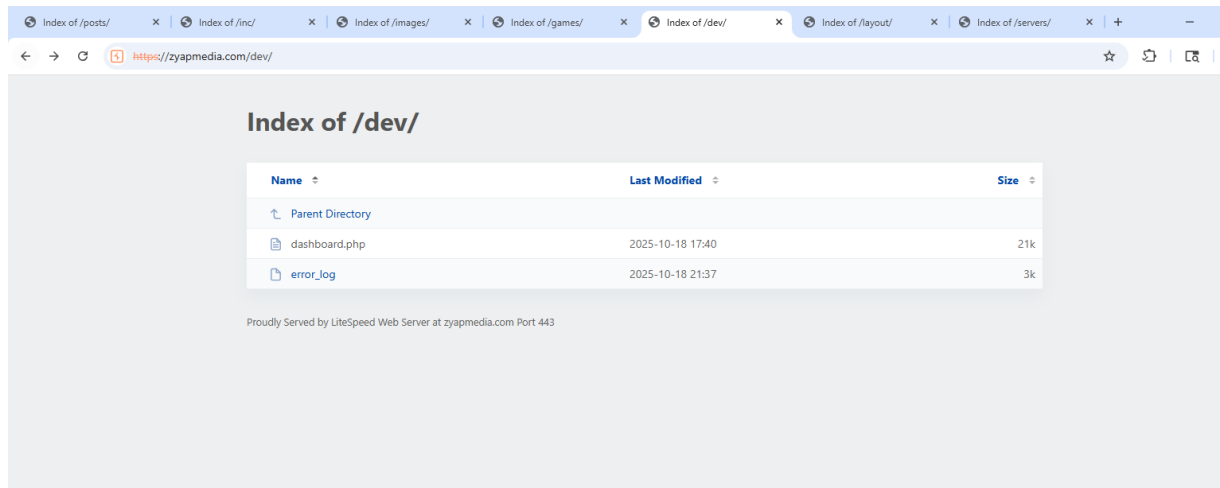
DIRB v2.22
By The Dark Raver

START_TIME: Mon Mar 9 03:43:10 2026
URL_BASE: https://test.zyapmedia.com/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
OPTION: Not Stopping on warning messages

GENERATED WORDS: 4612

--- Scanning URL: https://test.zyapmedia.com/ ---
+ https://test.zyapmedia.com/.svn (CODE:403|SIZE:1242)
=> DIRECTORY: https://test.zyapmedia.com/~adm/
=> DIRECTORY: https://test.zyapmedia.com/~admin/
=> DIRECTORY: https://test.zyapmedia.com/~administrator/
=> DIRECTORY: https://test.zyapmedia.com/~amanda/
=> DIRECTORY: https://test.zyapmedia.com/~apache/
=> DIRECTORY: https://test.zyapmedia.com/~bin/
=> DIRECTORY: https://test.zyapmedia.com/~ftp/
=> DIRECTORY: https://test.zyapmedia.com/~guest/
=> DIRECTORY: https://test.zyapmedia.com/~http/
=> DIRECTORY: https://test.zyapmedia.com/~httpd/
=> DIRECTORY: https://test.zyapmedia.com/~log/
=> DIRECTORY: https://test.zyapmedia.com/~logs/
=> DIRECTORY: https://test.zyapmedia.com/~lp/
=> DIRECTORY: https://test.zyapmedia.com/~mail/
=> DIRECTORY: https://test.zyapmedia.com/~nobody/
=> DIRECTORY: https://test.zyapmedia.com/~operator/
=> DIRECTORY: https://test.zyapmedia.com/~root/
=> DIRECTORY: https://test.zyapmedia.com/~sys/
=> DIRECTORY: https://test.zyapmedia.com/~sysadm/
=> DIRECTORY: https://test.zyapmedia.com/~sysadmin/
=> DIRECTORY: https://test.zyapmedia.com/~test/
=> DIRECTORY: https://test.zyapmedia.com/~tmp/
=> DIRECTORY: https://test.zyapmedia.com/~user/
=> DIRECTORY: https://test.zyapmedia.com/~webmaster/
=> DIRECTORY: https://test.zyapmedia.com/~www/
=> Testing: https://test.zyapmedia.com/ad_js
```

Directory enum’a başladım ana domain üzerinde. Sonuçları test subdomain’ine kıyasla çok daha şaşırtıcıydı.

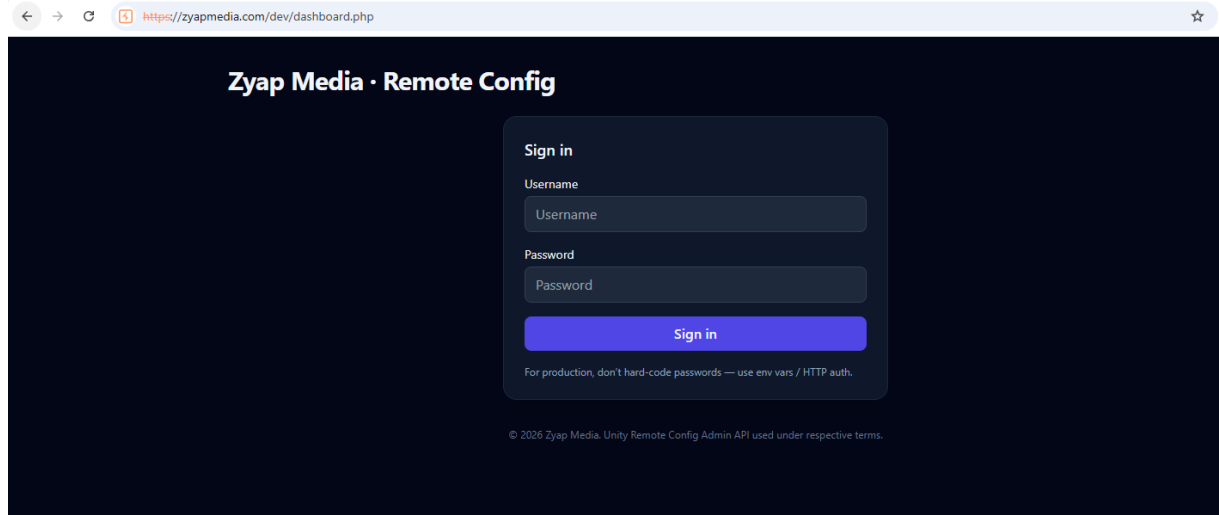


Burada “Directory Listing Leading” veya “Session Information Disclosure” adı ile tanımlanabilecek bir risk var. Kısaca erişememiz gereken dizinlere erişebildiğimiz zaman bunun gibi durumlar olur. İçerideki içeriğin ne kadar hassas olduğu önemli değil, bir saldırgan böyle önemsiz yerlerden içeriye girebilecek bir yol oluşturabilir.

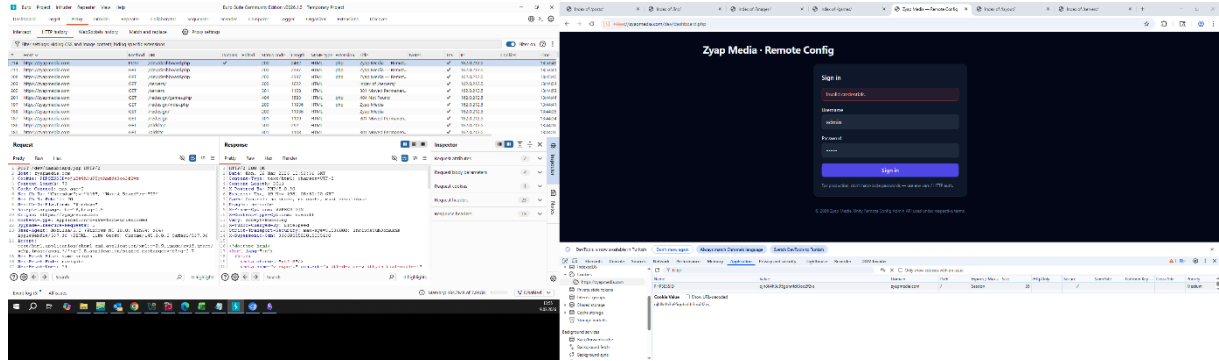
Bulduğum dizinler:

/posts/, /inc/, /images/, /games/, /dev/ (asıl bingo bu), /layout/, /servers/

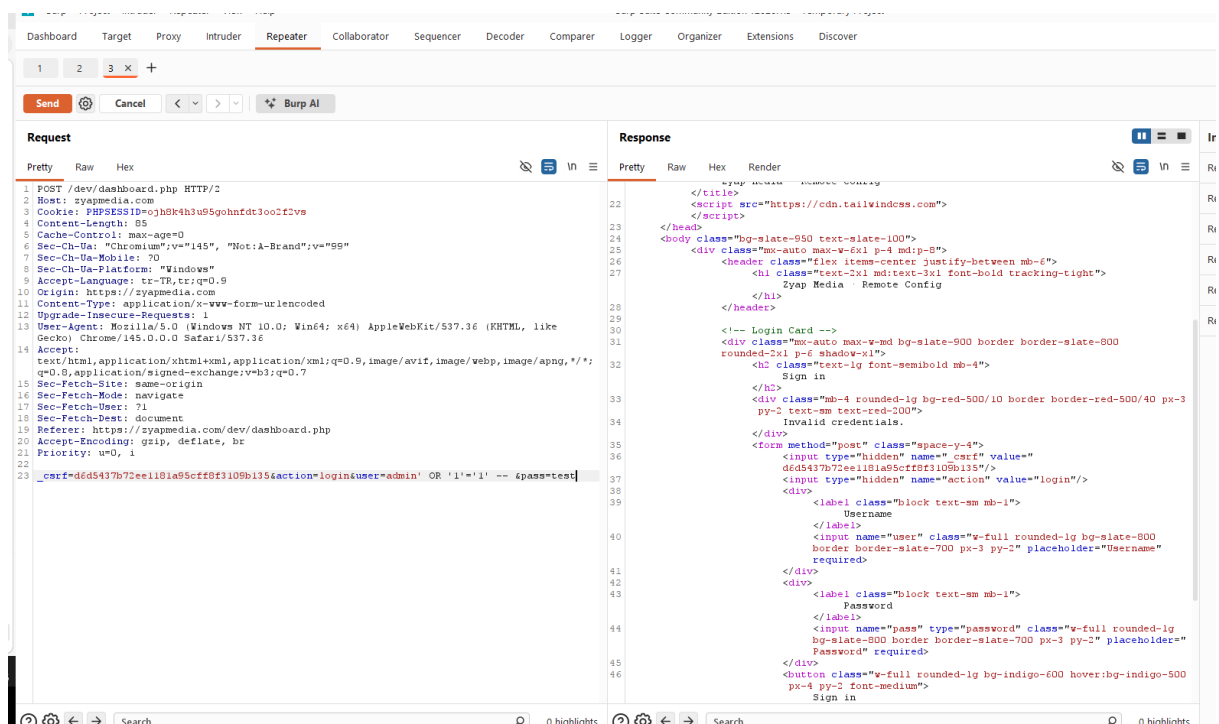
Buradaki dizinlerin çoğunda ya hiçbir şey yok yada işimize yaramayacak dosyalar var ama dev dizininde dashboard.php direkt gözüme takıldı.

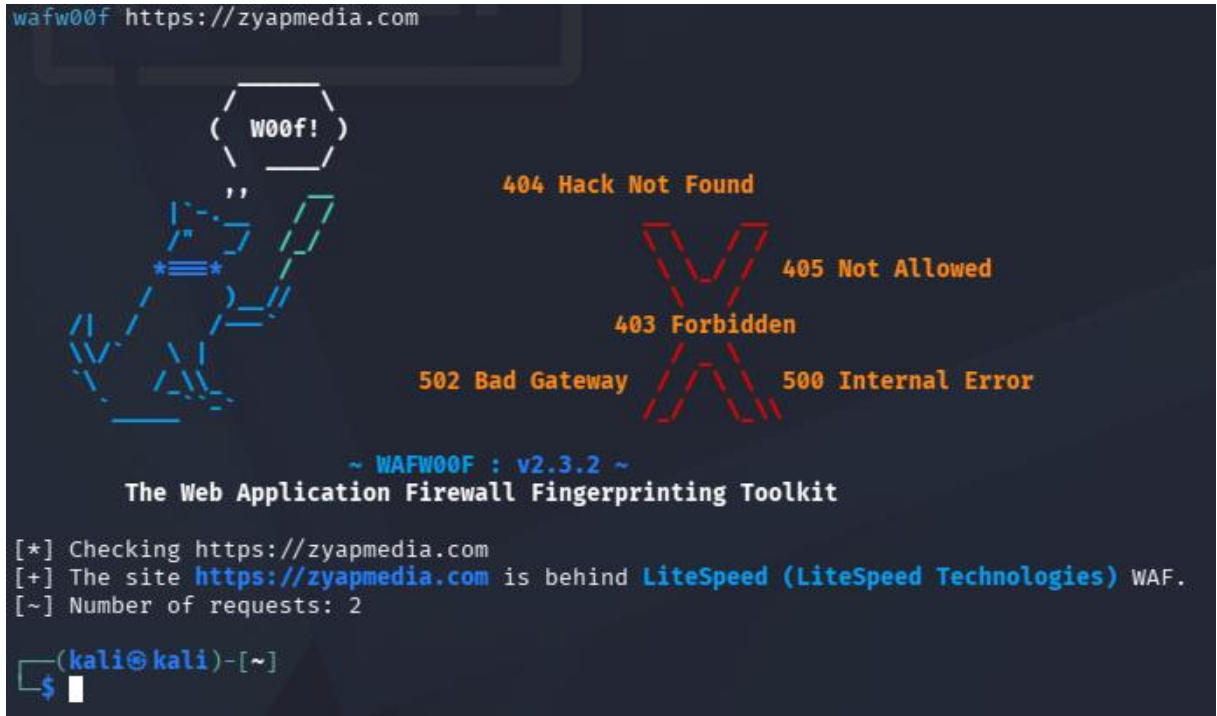


Cpanel dışında bir login page bulduk bu çok büyük bir ilerleme.

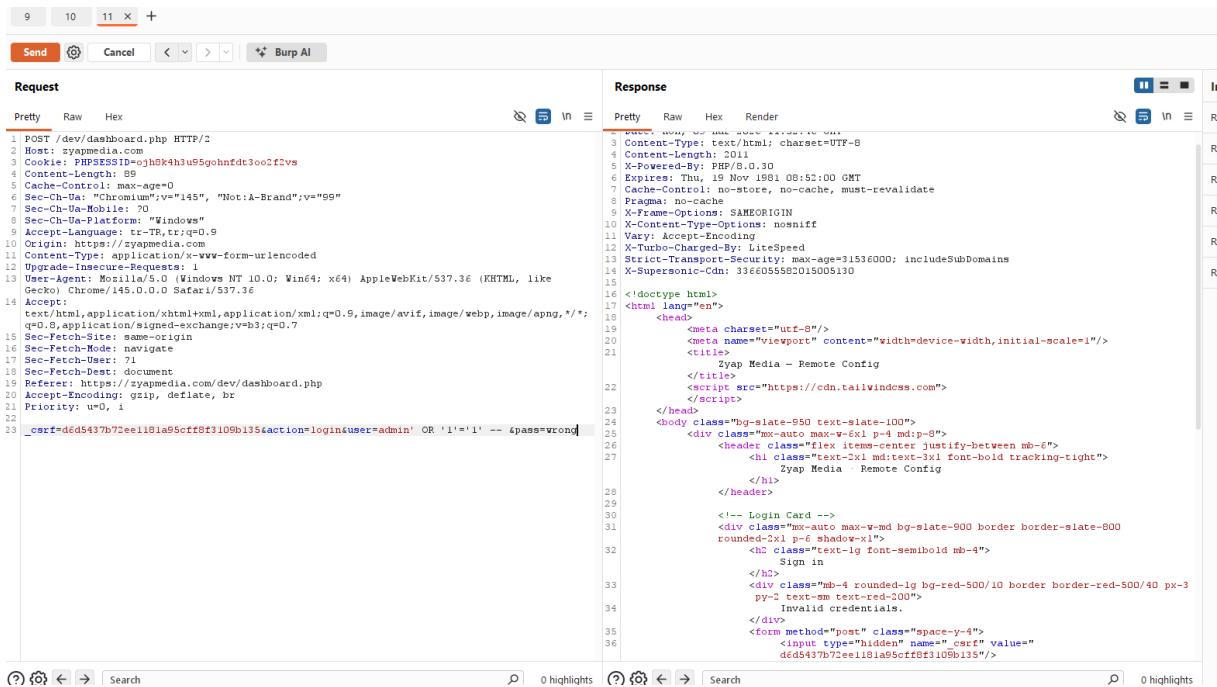


CSRF token ile giriş yapmaya çalıştım. Bir çok kere sql injection denedim.





Waf'ın ne olduğuna baktım.



Hala invalid creds çıktısı alıyoruz. Giriş denemeleri başarılı olmasada raporlamaya geçecek birkaç nokta bulduk.

Test Edilen Endpointler:

Hedef: <https://zyapmedia.com/dev/dashboard.php>

Method: POST

Parametre: _csrf, action, user, pass

WAF: LiteSpeed Web Application Firewall

Backend: PHP 8.0.30 + Tailwind CSS

Session: PHPSESSID cookie-based

Kullanılan Payloadlar:

Manuel Testler: user=admin' -- &pass= | user=admin' OR 1=1 -- &pass= | user=admin' UNION SELECT &pass= | user=admin') OR ('1'='1 &pass=

_csrf=d6d5437b72ee1181a95cff8f3109b135&action=login&user=' OR '1'='1' -- &pass=test

_csrf=d6d5437b72ee1181a95cff8f3109b135&action=login&username=admin' OR '1'='1' -- &pass=test

_csrf=d6d5437b72ee1181a95cff8f3109b135&action=login&user=admin' OR '1'='1' -- &pass=wrong

_csrf=d6d5437b72ee1181a95cff8f3109b135&action=login&user=admin' AND SLEEP(5)-- &pass=test

_csrf=d6d5437b72ee1181a95cff8f3109b135&action=login&user=admin' UNION SELECT 1,2,3--
&pass=test

_csrf=d6d5437b72ee1181a95cff8f3109b135&action=login&user=<script>alert`1`</script>&pass=test

CSRF Token:

Token değişmiyor, token statik -> Kesinlik olmamakla beraber CSRF token saldırıları imkansız.

Diğer Bulgular:

Wappalyzer (PHP 8.0.30 + LiteSpeed)

CSRF token ömrü test edildi (token aynı)

Rate limit testi manuel olarak yapıldı. IP block oranı düşük.

User Enumeration yok. Bütün çıktılar invalid credentials veriyor.

CVSS 3.1

1. Zafiyet: Statik CSRF token

Skor: 5.4

[Common Vulnerability Scoring System Version 3.1 Calculator](#)

2. Zafiyet: Directory Listing (Açık dizinler)

Skor: 5.3

[Common Vulnerability Scoring System Version 3.1 Calculator](#)

Öneriler:

CSRF token'ı her session'da değiştirmek

Dizin listeleme kapatmak (403)

Rate limiting eklemek (IP başına)

PHP sürümünü gizlemek

BÖLÜM D: Mühendislik Vizyonu (Reflection)

Senaryo: Hedef şirkette iki farklı XSS zafiyeti buldunuz. Birincisi, şirketin ana sayfasında kimsenin uğramadığı bir "Hakkımızda" sayfasındaki arama çubuğunda (Reflected XSS). İkincisi ise yöneticilerin girdiği iç ağdaki (Admin Panel) yorumlar bölümünde (Stored XSS).

Sadece "İkisi de XSS" diyerek geçemeyiz. Bu iki zafiyetin CVSS skorları ve şirkete vereceği zarar (Impact) neden birbirinden tamamen farklıdır? VDP yetkilisine bu iki açığın risk seviyesini nasıl kıyaslayarak açıklarsınız?

Cevap:

İki adet XSS zafiyeti buldum ama riskleri biraz farklı.

İlk bulgu, hakkımızda sayfasında Reflected XSS var. Bunu sömürmek için saldırganın kurbanla bir iletişimde olması gerekir. Sosyal mühendislik gerektiren bir saldırı aslında. Bu neden o kadar da kritik olduğu söylenemez, olay tamamen kurbanın kullanım farkındalığına kalıyor.

Ama ikinci bulguya bakarsak işler biraz değişiyor admin paneli ve Stored XSS. Bu gerçekten sıkıntılı. Saldırgan yorumlar kısmına XSS payload'ı gömerse o sayfaya giren bütün kullanıcıların tarayıcılarında bu payload çalışır. Bununla birlikte saldırgan kod çalıştırabilir, yeni admin hesabı açabilir, ransomware yani fidye yazılım gömebilir. Kısaca admin yetkileri ile istediği her şeyi yapabilir diyebiliriz.

Doğal olarak Reflected XSS saldırısının CVSS skoru Stored XSS saldırısına kıyasla düşük olacaktır. Bir yandan Stored XSS tarafının **ÇOK KRİTİK** olduğunu unutmamak lazım.